NETBOX PLUGIN

# User PIN – návod

Kompletný návod pre NetBox 4.7+, overený v kóde

Verzia 3.1.0 · 2026-11-04
Inštalácia · kľúč · e-maily · PIN a 2FA · používatelia · roly · schvaľovanie · nastavenia · oblasti · ochrana a výnimky · osoby len s PIN-om · pracovný čas · príkazy · riešenie problémov · zmeny
github.com/ArK761/NetBox_UserPIN

# Obsah


1. Čo plugin potrebuje a čo pridá do NetBoxu
   - 1.1 Požiadavky
   - 1.2 Závislosti (Python balíky)
   - 1.3 Čo plugin pridá do NetBoxu
2. Inštalácia
   - 2.1 1. Balíky
   - 2.2 2. Šifrovací kľúč
   - 2.3 3. Konfigurácia
   - 2.4 4. Migrácie a reštart
   - 2.5 5. Kontrola, že všetko beží
   - 2.6 6. Prvé kroky v rozhraní
   - 2.7 Čo sa stane, keď je konfigurácia zlá
   - 2.8 Nepovinné nastavenia v konfigurácii
3. Aktualizácia pluginu a NetBoxu
   - 3.1 Aktualizácia len pluginu (jeden riadok)
   - 3.2 Upgrade samotného NetBoxu
4. Šifrovací kľúč
   - 4.1 Čo kľúč chráni
   - 4.2 Ako kľúč vygenerovať
   - 4.3 Aký kľúč plugin prijme
   - 4.4 Zápis do konfigurácie
   - 4.5 Zálohovanie kľúča
   - 4.6 Výmena kľúča (rotácia)
   - 4.7 Čo vypisuje `userpin_check`
5. E-maily: ako plugin posiela poštu
   - 5.1 Kedy sa e-mail naozaj odošle
   - 5.2 Z čoho plugin posiela
   - 5.3 Ako e-mail vyzerá
6. Stránka Mail
   - 6.1 Nastavenie e-mailu (polia)
   - 6.2 Upozornenia a zabudnutý PIN
   - 6.3 Stav a test pripojenia
   - 6.4 Testovací e-mail
7. Povolené e-mailové domény
   - 7.1 Pridanie a overenie domény
8. Ktoré e-maily plugin posiela (jadro PIN)
9. E-maily: keď nejdú
10. Môj PIN
    - 10.1 Kto smie používať PIN
    - 10.2 Stránka Môj PIN
    - 10.3 Nastavenie a zmena PINu
    - 10.4 Odomknutie
    - 10.5 Zlé pokusy a zablokovanie
    - 10.6 Platnosť a rotácia
    - 10.7 Zabudnutý PIN (samoobsluha)
11. Dvojfaktorové overenie (2FA)
    - 11.1 Záložné kódy
    - 11.2 Strata telefónu
    - 11.3 Potvrdenie administratívnych akcií
12. Používatelia (stránka PINov)
    - 12.1 Filtre
    - 12.2 Stĺpce
    - 12.3 Akcie pri používateľovi
    - 12.4 Kto koho smie spravovať
    - 12.5 Núdzový reset 2FA
13. Roly: CORE a oddelenia
    - 13.1 Kto čo vidí a robí
    - 13.2 Pozvánka na rolu
    - 13.3 Minimum a zánik roly
    - 13.4 Zástupcovia CORE (stránka CORE (zástupcovia), len master)
    - 13.5 Oddelenia
    - 13.6 Presuny medzi oddeleniami
    - 13.7 Moje roly
14. Schvaľovanie „štyri oči“
    - 14.1 Zapnutie a kategórie
    - 14.2 Priebeh žiadosti
15. Audit log
    - 15.1 Čo sa zapisuje
16. Nastavenia
    - 16.1 Všeobecné
    - 16.2 Prístup a pravidlá PINu
    - 16.3 Rotácia
    - 16.4 Odomknutie
    - 16.5 Ochrana
    - 16.6 Schvaľovanie štyri oči
    - 16.7 Chránené oblasti
    - 16.8 Čo je na iných stránkach
17. Chránené oblasti
    - 17.1 Základná myšlienka
    - 17.2 Stránka Chránené oblasti
    - 17.3 Detail oblasti
    - 17.4 Skupina: práva
    - 17.5 Skupina: záznamy, ktoré vidí
    - 17.6 Polia
    - 17.7 Záložky detailu a karty
    - 17.8 Žiadosť o prístup
    - 17.9 Môj prístup
    - 17.10 Čo sa vynucuje
    - 17.11 Oblasť pluginu
18. Globálna ochrana (ZAP / VYP) a strážcovia

- 18.1 ZAP a VYP
- 18.2 Správcovia ochrany (strážcovia)
- 18.3 Čo používatelia vidia
- 18.4 E-maily o zmenách v chránených oblastiach
- 18.5 Núdza na serveri

19. Výnimky
- 19.1 Zapnutá a vypnutá výnimka (prepínač)
- 19.2 Koniec výnimky (dátum a čas)
- 19.3 Hľadanie a zoznam pre veľa používateľov
- 19.4 Pridanie výnimky
- 19.5 Čo smie používateľ s výnimkou
- 19.6 API tokeny a PIN: vedomá bezpečnostná hranica
- 19.7 Keď PIN nevie prečítať stav ochrany

20. Správcovia úsekov

21. Ľudia len s PIN-om (PIN-only)
- 21.1 Nový prístup (formulár)
- 21.2 Prvé prihlásenie osoby
- 21.3 Osobné číslo a pravidlá prihlásenia
- 21.4 Čo osoba vidí: len svoje oblasti
- 21.5 Bežné prihlasovanie: jedna spoločná adresa
- 21.6 Čo osoba vidí a nemôže
- 21.7 Zlé PINy
- 21.8 Akcie pri osobe
- 21.9 Relácia osoby
- 21.10 E-maily oboma smermi

22. Pracovný čas
- 22.1 Pravidlá
- 22.2 Čo sa deje mimo času

23. Príkazy na serveri

24. Kontrola: pin_check.sh

25. Bezpečnostný model

26. Použitie z iného pluginu
- 26.1 Oblasť pluginu

27. Riešenie problémov

28. Zmeny
- 28.1 3.1.0: podmienky polí a pracovný čas
- 28.2 3.0.0: bezpečnostné opravy po audite
- 28.3 2.5.0: zmeny oproti 2.0.0 (výnimky, e-maily a audit, osobné číslo)
- 28.4 Kľúče a bezpečnosť
- 28.5 Nový model ochrany
- 28.6 Správcovia úsekov a žiadosti
- 28.7 Osoby len s PIN-om
- 28.8 Pracovný čas
- 28.9 Nástroje
- 28.10 Čo plugin zatiaľ nerobí

# 1. Čo plugin potrebuje a čo pridá do NetBoxu

**Kto:** správca servera (prístup k príkazovému riadku a k `configuration.py`).
**Kedy:** pred prvou inštaláciou; pri každej aktualizácii pluginu alebo NetBoxu.
**Závisí od:** NetBox 4.7.0 alebo novší, Python 3.12+, bežiaci worker `netbox-rq`, prístup na internet (GitHub, PyPI) pri inštalácii.

## 1.1 Požiadavky

| Čo | Podrobnosti |
|---|---|
| NetBox | verzia **4.7.0 a novšia** (plugin má `min_version = 4.7.0` a hornú hranicu nemá). Ak starší NetBox, plugin sa nenačíta. |
| Python | 3.12 alebo novší (`requires-python >= 3.12`). |
| Worker `netbox-rq` | Plugin si registruje systémovú úlohu **User PIN role housekeeping**, ktorá beží **každých 5 minút**. Spracúva vypršané pozvánky, presuny a výnimky, posiela pripomienky, vracia práva po dočasnom odovzdaní, oznamuje koniec platnosti prístupov len cez PIN a posiela zhrnutia zmien. E-maily o zmenách osoby len s PIN-om idú tiež cez frontu `default`. Keď worker nebeží, tieto veci sa nevykonajú. |
| Databáza | tabuľky pluginu vytvorí `migrate` (migrácie 0001 až 0046). |

## 1.2 Závislosti (Python balíky)

| Balík | Na čo slúži | Keď chýba |
|---|---|---|
| `argon2-cffi >= 23.1` | hashovanie PINu (Argon2id) | NetBox sa nespustí: `ModuleNotFoundError: No module named 'argon2'` |
| `cryptography >= 42` | šifrovanie AES-256-GCM a odvodenie kľúča (HKDF) | NetBox sa nespustí |
| `segno >= 1.5` | QR kód pri nastavení 2FA | stránky pluginu sa nenačítajú (chyba pri importe `segno`) |
| `holidays >= 0.50` | štátne sviatky pre pracovný čas osôb len s PIN-om | plugin beží, kontrolujú sa len dni a hodiny (bez sviatkov) |

**Pozor:** inštalácia s voľbou `--no-deps` závislosti neinštaluje. Na serveri, kde plugin ešte nebol, ich nainštaluj osobitne (pozri kapitolu Inštalácia).

## 1.3 Čo plugin pridá do NetBoxu

- **Menu „User PIN“** s položkami: *Môj PIN*, *Moje roly*, *Môj prístup*, *Test odomknutia*, *Ľudia len s PIN-om*, *Používatelia*, *Oddelenia*, *Chránené oblasti*, *Schvaľovania (štyri oči)*, *Audit log*, *Nastavenia*, *Mail*, *CORE (zástupcovia)*. Ktorú položku vidí ktorý používateľ, závisí od jeho roly (opisuje to kapitola o rolách).
- **Adresa pluginu**: `/plugins/user-pin/`.
- **Dva middleware**, ktoré sa zaradia automaticky: `PluginLanguageMiddleware` (jazyk stránok pluginu) a `AreaGuardMiddleware` (strážca chránených oblastí a globálnej ochrany). Do `configuration.py` sa nezapisujú.

- **Tri typy udalostí** v notifikáciách NetBoxu (zvonček): *PIN four-eyes approval requested*, *PIN area access requested*, *PIN role / department change*.
- **Oprávnenia NetBoxu** s názvami `User PIN: …` (zástupcovia, editori nastavení, oddelenia). Plugin ich vytvára a spravuje sám: neupravuj ich ručne.

# 2. Inštalácia

**Kto:** správca servera ( `root` alebo `sudo` ).
**Kedy:** raz, na každom serveri NetBoxu zvlášť (test, produkcia).
**Závisí od:** kapitola Čo plugin potrebuje; vygenerovaný kľúč (nasledujúca kapitola).

## 2.1 1. Balíky

```
source /opt/netbox/venv/bin/activate
pip install "argon2-cffi>=23.1" "cryptography>=42" "segno>=1.5" "holidays>=0.50"
pip install --upgrade --force-reinstall --no-deps "git+https://github.com/ArK761/NetBox_UserPIN.git
@3.1.0"
```

Namiesto `@3.1.0` môžeš použiť ľubovoľný tag alebo commit. Pip môže po inštalácii napísať upozornenie o `python-dateutil` (pozri Riešenie problémov): je neškodné.

## 2.2 2. Šifrovací kľúč

Vygeneruj ho a ulož si ho bokom, **skôr než** plugin zapneš. Postup je v kapitole *Šifrovací kľúč*.

## 2.3 3. Konfigurácia

V `/opt/netbox/netbox/netbox/configuration.py` pridaj `'netbox_user_pin'` do `PLUGINS` a blok do `PLUGINS_CONFIG`:

```
PLUGINS = [
    # ... tvoje ostatné pluginy ...
    'netbox_user_pin',
]

PLUGINS_CONFIG = {
    # ... nastavenia ostatných pluginov ...
    'netbox_user_pin': {
        'encryption_keys': {'k1': '<tvoj kľúč>'},
        'active_key_id': 'k1',
    },
}
```

> **Pozor na dva bloky.** Ak už v `PLUGINS` a `PLUGINS_CONFIG` iné pluginy máš, riadok a blok sa **pridajú**, neprepisujú sa. Skontroluj aj čiarky a apostrofy: chyba v súbore zastaví celý NetBox.

## 2.4 4. Migrácie a reštart

```
cd /opt/netbox/netbox
python manage.py migrate netbox_user_pin
sudo systemctl restart netbox netbox-rq
```

Príkaz `migrate netbox_user_pin` vytvorí tabuľky pluginu. Ak hlási *No installed app with label 'netbox_user_pin'*, plugin nie je v zozname `PLUGINS`.

## 2.5 5. Kontrola, že všetko beží

```
python manage.py showmigrations netbox_user_pin | tail -3      # všetky riadky majú [X]
python manage.py userpin_check                                  # po čerstvej inštalácii: OK: 0 ...
failed: 0
systemctl is-active netbox netbox-rq                            # active, active
```

V NetBoxe sa v menu objaví **User PIN**. V *Nastavenia* je karta *Šifrovací kľúč* s aktívnym kľúčom a jeho odtlačkom.

## 2.6 6. Prvé kroky v rozhraní

1. Prihlás sa ako superuser → **User PIN → Môj PIN** → *Nastaviť PIN* a *Nastaviť 2FA* (administratívne akcie vyžadujú 2FA).
2. Na stránke **Mail** nastav odosielanie a over aspoň jednu doménu (pozri kapitolu E-maily).
3. Na stránke **Používatelia** povoľ používanie PINu tým, ktorí ho majú mať.

## 2.7 Čo sa stane, keď je konfigurácia zlá

Plugin pri štarte overí kľúče a **NetBox sa nespustí**, ak je s nimi problém (nikdy sa kľúč nevygeneruje ani neprepne potichu). Preto vždy po úprave `configuration.py` sleduj `journalctl -u netbox -n 50`.

| Chyba pri štarte | Príčina |
|---|---|
| `encryption_keys must be a non-empty dict` | chýba `encryption_keys` alebo je prázdne |
| `invalid key id '…'` | id kľúča je prázdne alebo obsahuje dvojbodku (`:`) |
| `must be a base64 32 byte key or a secret of at least 32 characters` | kľúč je kratší než 32 znakov a nie je platný base64 kľúč |
| `several encryption keys are configured; set 'active_key_id'` | kľúčov je viac a chýba `active_key_id` |
| `active_key_id '…' is not in encryption_keys` | aktívne id nie je medzi kľúčmi |

## 2.8 Nepovinné nastavenia v konfigurácii

| Nastavenie | Predvolené | Význam |
|---|---|---|
| `encryption_keys` | – (povinné) | slovník `{id_kľúča: kľúč}` |
| `active_key_id` | jediný kľúč | kľúč na nové šifrovanie; povinné, keď je kľúčov viac |
| `argon2_time_cost` | 3 | počet iterácií Argon2id |
| `argon2_memory_cost` | 65536 | pamäť Argon2id v KiB (64 MiB) |
| `argon2_parallelism` | 4 | počet vlákien Argon2id |
| `cli_venv` | /opt/netbox/venv | cesta, ktorú plugin ukáže v núdzovom príkaze na resetovanie 2FA |
| `cli_netbox_dir` | /opt/netbox/netbox | to isté pre adresár NetBoxu |

Všetko ostatné sa nastavuje v rozhraní (**User PIN → Nastavenia** a **Mail**).

# 3. Aktualizácia pluginu a NetBoxu

**Kto:** správca servera.
**Kedy:** pri novej verzii pluginu alebo NetBoxu.
**Závisí od:** zálohu databázy (pred migráciou), pripnutú verziu v `local_requirements.txt`.

## 3.1 Aktualizácia len pluginu (jeden riadok)

```
sudo bash -c 'source /opt/netbox/venv/bin/activate && pip install --upgrade holidays && pip install --upgrade --force-reinstall --no-deps "git+https://github.com/ArK761/NetBox_UserPIN.git@<tag-alebo-commit>" && cd /opt/netbox/netbox && python manage.py migrate netbox_user_pin && systemctl restart netbox netbox-rq'
```

**Produkcia:** pred migráciou urob zálohu databázy, napríklad `sudo -u postgres pg_dump netbox | gzip > /root/netbox-$(date +%F-%H%M).sql.gz`. Kľúče v `configuration.py` pritom nemeň.

## 3.2 Upgrade samotného NetBoxu

`upgrade.sh` vytvorí virtuálne prostredie **znova** a nainštaluje len to, čo je v `requirements.txt` a `local_requirements.txt`. Plugin, ktorý tam nie je, po upgrade zmizne. Riadky v `/opt/netbox/local_requirements.txt`:

```
netbox-librenms-plugin
netbox-qrcode
git+https://github.com/ArK761/NetBox_UserPIN.git@3.1.0
```

- Balík z PyPI stačí zapísať samotným menom. Plugin z GitHubu potrebuje celý odkaz.
- Riadok bez `@…` nainštaluje **posledný commit vetvy** `main` (nie posledný release; pip GitHub Releases nepozná, pozná len vetvy, tagy a commity). Ak je kód plugin na inej vetve, ponechaj pripnutý commit.
- Po upgrade skontroluj verzie pluginov (odznak *User PIN vX · commit*) a spusti `userpin_check`.

# 4. Šifrovací kľúč

**Kto:** výhradne správca servera (kľúč je len v `configuration.py`). Nikto v rozhraní ho nevidí; v *Nastaveniach* je len jeho meno a odtlačok.
**Kedy:** vygeneruješ ho pred prvou inštaláciou. Vymieňaš ho pri podozrení z úniku alebo podľa firemnej politiky.
**Závisí od:** všetko, čo plugin šifruje, sa bez kľúča nedá prečítať. Kľúč preto musí byť zálohovaný oddelene od databázy.

## 4.1 Čo kľúč chráni

Pod kľúčom je uložené (šifrovanie AES-256-GCM, viazané na konkrétneho používateľa):

- hash PINu každého používateľa (PIN sa najprv hashuje Argon2id so soľou a až hash sa šifruje),
- tajomstvo 2FA (TOTP) každého používateľa,

- záložné kódy 2FA,
- SMTP heslo zo stránky Mail.

Kľúčom sa navyše počítajú odtlačky (nešifrujú sa): vyhľadávací index PINu pre osoby len s PIN-om bez osobného čísla a overovacie kódy domén. Výpis databázy samotný teda neobsahuje nič použiteľné, ani čo by sa dalo lámať offline.

## 4.2 Ako kľúč vygenerovať

```
# kým plugin ešte nebeží – obyčajný Python:
python3 -c "import base64,os; print(base64.urlsafe_b64encode(os.urandom(32)).decode())"

# alebo ľubovoľne dlhý náhodný text:
openssl rand -base64 64 | tr -d '\n'

# keď plugin už beží:
cd /opt/netbox/netbox && python manage.py userpin_generate_key --key-id k1
```

Príkaz `userpin_generate_key` kľúč len vypíše, nikam ho neukladá. `--key-id` je iba názov, ktorý dostane v konfigurácii (predvolene `k1`).

## 4.3 Aký kľúč plugin prijme

| Tvar kľúča | Čo sa stane |
|---|---|
| base64 (urlsafe) reťazec, ktorý je presne 32 bajtov | použije sa priamo |
| akýkoľvek iný reťazec s **aspoň 32 znakmi** | 32-bajtový kľúč sa z neho odvodí (HKDF-SHA256) |
| kratší reťazec | NetBox sa nespustí (chyba pri štarte) |

Dlhší kľúč nie je silnejší: šifrovanie vždy používa 256 bitov. Rozhoduje, aby bol **náhodný** (nie vymyslené heslo). Názov kľúča (`k1`) nesmie byť prázdny ani obsahovať dvojbodku.

## 4.4 Zápis do konfigurácie

```
PLUGINS_CONFIG = {
    'netbox_user_pin': {
        'encryption_keys': {'k1': '<kľúč>'},
        'active_key_id': 'k1',      # pri jedinom kľúči sa dá vynechať
    },
}
```

## 4.5 Zálohovanie kľúča

> - Ulož kľúč **offline** (správca hesiel, trezor) a **nikdy do tej istej zálohy ako databázu**. Kto má oboje, môže dešifrovať.
> - **Keď sa kľúč stratí**, dáta NetBoxu ostanú nedotknuté, ale všetko, čo plugin pod kľúčom uložil, je nenávratne preč: PINy, 2FA, záložné kódy, SMTP heslo a prihlasovanie osôb len s PIN-om. Všetci si ich musia nastaviť znova.
> - Skontroluj, že záloha sedí: v *User PIN → Nastavenia* je karta **Šifrovací kľúč** s položkami *Aktívny kľúč*, *Odtlačok* a *Nastavené kľúče*. Odtlačok porovnaj s poznámkou pri offline zálohe.

### 4.6 Výmena kľúča (rotácia)

Pri rotácii sa všetky šifrované hodnoty prešifrujú novým kľúčom. Starý kľúč ostáva v konfigurácii, kým sa všetko nepresunie.

1. **Záloha databázy** (pre istotu).
2. Vygeneruj nový kľúč a ulož ho bokom.
3. V `configuration.py` pridaj nový kľúč **vedľa starého** a nastav ho ako aktívny:

```
'encryption_keys': {'k1': '<starý>', 'k2': '<nový>'},
'active_key_id': 'k2',
```

4. Reštartuj NetBox: `sudo systemctl restart netbox netbox-rq`.
5. Prešifruj: `python manage.py userpin_rotate_key`. Beží v jednej transakcii: ak čo i len jedna hodnota sa nedá dešifrovať, **nič sa nezmení** a príkaz vypíše, čo zlyhalo. Po úspechu zapíše do auditu udalosť o rotácii.
6. Over: `python manage.py userpin_check`.
7. **Starý kľúč odstráň až keď `userpin_check` napíše** *Everything decrypts with the active key; old keys can be removed.*

**Prečo starý kľúč nemazať hneď:** index osôb len s PIN-om bez osobného čísla (osoby s číslom ho nemajú) sa presunie na nový kľúč až pri ďalšom prihlásení každej osoby. Kým sa niektorá neprihlási, čaká na starý kľúč. Príkaz to vypíše (*PIN-only accesses still on an old key: N*) a potom ešte *Do NOT remove the old key yet*.

### 4.7 Čo vypisuje `userpin_check`

| Riadok | Význam |
|---|---|
| `Active key: k2 fingerprint …` | aktívny kľúč a jeho odtlačok |
| `OK: N, encrypted with a non-active key: M, failed: F, PIN-only accesses still on an old key: G` | N hodnôt sa dešifrovalo; M ešte používa starý kľúč; F sa nedá dešifrovať; G osôb len s PIN-om čaká na prihlásenie |
| chyba (príkaz skončí chybou) | aspoň jedna hodnota sa nedá dešifrovať: zlý alebo chýbajúci kľúč. Nemeň `k1` a pošli výpis |

> Plugin kľúč nikdy nevytvorí ani neprepne sám. Chýbajúci alebo zlý kľúč skončí chybou, nie tichou zmenou.

## 5. E-maily: ako plugin posiela poštu

**Kto nastavuje:** master a zástupcovia CORE s oprávnením upravovať nastavenia (stránka *Mail*). Server NetBoxu (`EMAIL` v `configuration.py`) nastavuje správca servera.

**Kedy:** hneď po inštalácii. Bez nastavenej pošty plugin **neposiela žiadne e-maily**: nefunguje obnova zabudnutého PINu, pozvánky do rolí ani upozornenia.

**Závisí od:** odosielateľ + SMTP server, **overená doména** príjemcu, adresa v účte príjemcu.

### 5.1 Kedy sa e-mail naozaj odošle

E-mail používateľovi odíde len keď sú splnené **všetky štyri** podmienky:

1. pošta je nastavená (pozri nižšie),
2. používateľ má v účte e-mailovú adresu,
3. doména tejto adresy je v zozname **overených** domén (kapitola Domény),
4. pre bezpečnostné upozornenia: vypínač *Bezpečnostné upozornenia e-mailom* je zapnutý.

Ak niečo z toho chýba, e-mail sa **potichu neodošle** a akcia sa vykoná. Stav e-mailu používateľa vidno na stránke *Používatelia* v stĺpci E-mail: *bez e-mailu* (chýba adresa), *doména* (adresa mimo overených domén). Inak sa ukáže samotná adresa. Pri zlyhaní odoslania (napr. server nedostupný) sa zapíše do auditu udalosť *E-mail failed* s chybou; akcia, ktorá e-mail spustila, sa tým nepokazí.

### 5.2 Z čoho plugin posiela

| Zdroj | Kedy sa použije | Čo musí byť nastavené |
|---|---|---|
| **SMTP z tejto stránky** | keď je vyplnený **SMTP server aj adresa odosielateľa** | stránka Mail → Nastavenie e-mailu |
| **Konfigurácia NetBoxu** | keď SMTP server na stránke Mail **nie je** vyplnený a NetBox má v `configuration.py` blok `EMAIL` | `EMAIL['SERVER']` a `EMAIL['FROM_EMAIL']` (alebo adresa odosielateľa zo stránky Mail) |
| nič | ani jedno nie je nastavené | stav *nenastavené*: plugin e-maily neposiela |

Používatelia nikdy nezadávajú žiadne prihlasovacie údaje k pošte: používa sa jeden servisný účet.

### 5.3 Ako e-mail vyzerá

- Čistý text (bez HTML). Predmet má predponu `[NetBox PIN]` (napr. `[NetBox PIN] Your PIN was changed`).
- Na konci je pätička *NetBox User PIN. This is an automatic message.*
- Text je v jazyku z *Nastavení → Jazyk* (pre osoby len s PIN-om v jazyku, ktorý má nastavený ich prístup).
- Odosielateľ: *Meno odosielateľa* + adresa (predvolené meno *NetBox PIN*).

## 6. Stránka Mail

**Kto ju vidí:** CORE (master a zástupcovia). Ostatní stránku nemajú. Výnimka: ak existujú strážcovia ochrany aj aktívni zástupcovia CORE, superuser, ktorý nie je zástupca CORE, ju nevidí.
**Kto môže meniť:** master a zástupca CORE s oprávnením *Môže upravovať nastavenia* (zapína ho CORE na stránke CORE (zástupcovia)). Ostatní vidia stránku s nápisom *Iba na čítanie*.
**Potvrdenie:** uloženie vyžaduje PIN (a 2FA, ak je zapnuté *Vyžadovať 2FA aj pre nastavenia*). Test pripojenia a testovací e-mail potvrdenie nevyžadujú.
**Štyri oči:** ak je zapnuté schvaľovanie a voľba „… pre nastavenia a mailové nastavenia“ (predvolene zapnutá), uloženie nastavení pošty aj pridanie domény vytvoria žiadosť na schválenie druhou osobou.

## 6.1 Nastavenie e-mailu (polia)

| Pole | Predvolené | Význam |
|---|---|---|
| Meno odosielateľa | NetBox PIN | zobrazí sa ako meno odosielateľa |
| E-mailová adresa odosielateľa | prázdne | napr. `netbox@firma.sk`. Povinná, ak je vyplnený SMTP server |
| SMTP server | prázdne | napr. `mail.firma.sk`. Prázdne = použije sa konfigurácia NetBoxu |
| SMTP port | 25 | 1 až 65535 |
| SMTP časový limit (s) | 10 | 1 až 120 |
| Šifrovanie | Vypnuté | *Vypnuté (zvyčajne port 25)*, *STARTTLS (zvyčajne port 587)*, *SSL/TLS (zvyčajne port 465)* |
| Automatické TLS | zapnuté | pri vypnutom šifrovaní sa STARTTLS použije, keď ho server ponúka |
| SMTP autentifikácia | vypnutá | ak je zapnutá, treba SMTP používateľa aj heslo |
| SMTP používateľ | prázdne | servisný účet, z ktorého sa pošta posiela |
| SMTP heslo | prázdne | uloží sa **zašifrované kľúčom** a nikdy sa nezobrazí; prázdne pole pri úprave = ponechať aktuálne. Pri zapnutej autentifikácii je povinné, ak ešte nie je uložené |

Pri uložení plugin kontroluje: SMTP server bez adresy odosielateľa je chyba (*A sender address is needed together with the SMTP server*), autentifikácia bez používateľa alebo hesla je chyba.

## 6.2 Upozornenia a zabudnutý PIN

| Pole | Predvolené | Význam |
|---|---|---|
| Bezpečnostné upozornenia e-mailom | zapnuté | PIN nastavený / zmenený / resetovaný, zablokovanie, blížiaca sa expirácia, zmeny 2FA, zobrazenie záložných kódov. Vypnutie nemá vplyv na ostatné maily (kódy, pozvánky, roly, oblasti) |
| Samoobslužná obnova zabudnutého PINu | zapnutá | kód z e-mailu **a** kód 2FA spolu |
| Platnosť kódu na obnovu (minúty) | 15 | 5 až 60; platí aj pre overovací kód domény a pre kód na zobrazenie záložných kódov |

## 6.3 Stav a test pripojenia

Karta **Stav** ukáže *Používa sa*: *SMTP z tejto stránky*, *Konfigurácia NetBoxu* alebo *nenastavené*, a podľa toho server, účet (alebo *bez autentifikácie*) a odosielateľa. Tlačidlo **Test pripojenia** sa pripojí k SMTP serveru zo stránky (a prihlási sa) a napíše výsledok. Funguje len pre SMTP zo stránky Mail, nie pre konfiguráciu NetBoxu.

## 6.4 Testovací e-mail

Vyber príjemcu a stlač **Poslať testovací e-mail**. Vyberať sa dajú len používatelia, ktorí **smú používať PIN a majú e-mail v overenej doméne**; výber ukáže účet, meno aj adresu. Ak nikto nespĺňa podmienky, stránka to napíše. Výsledok: *Test e-mail sent to …* alebo chyba s odkazom na audit log.

# 7. Povolené e-mailové domény

**Kto:** ten, kto môže meniť nastavenia pošty (pozri vyššie).
**Kedy:** raz pre každú doménu, ktorá má dostávať e-maily. Pridať novú treba aj keď pribudne firma s inou doménou.
**Závisí od:** pošta musí byť nastavená a niekto s adresou v tej doméne musí vedieť prečítať kód.

Pošta ide **len na adresy v overených doménach**. Kým doména nie je overená, e-maily do nej neodídu (v zozname sa ukáže *neoverená – zatiaľ žiadne e-maily*; bez domén stojí *Žiadna doména – neposielajú sa žiadne e-maily*).

- Doména sa zapisuje napr. `@firma.sk` (zavináč môže byť aj chýbať; plugin ho odstráni a prevedie na malé písmená). Musí obsahovať bodku a nesmie obsahovať medzery.
- **Zhoda je presná:** `firma.sk` pustí `jan@firma.sk`, ale **nie** poddomény (`jan@mail.firma.sk`) ani podobné mená (`firma.sk.evil.com`).

## 7.1 Pridanie a overenie domény

1. V karte *Povolené e-mailové domény* napíš doménu a stlač **Pridať**. Hneď sa otvorí okno *Overenie domény*. (Ak je zapnuté schvaľovanie štyri oči, najprv sa pridanie musí schváliť.)
2. **1. Adresa v tejto doméne:** napíš jednu adresu, ktorá končí touto doménou, a stlač **Poslať kód**. Odíde e-mail s **8-miestnym kódom**.
3. **2. Kód z e-mailu:** zadaj kód a stlač **Overiť**.

Kód platí **Platnosť kódu na obnovu** minút (predvolene 15) a dá sa zadať najviac **5-krát** (potom treba poslať nový). Ak už kód máš, v okne je odkaz *Už máte kód? Zadajte ho priamo*. Pri úspechu sa uloží, kto doménu overil a cez akú adresu. Chyby: *The address must end with @doména*, *No mail server is configured*, *The code is wrong or expired*.

- **Znovu overiť** je dostupné kedykoľvek (napr. pre novú adresu); pri nej sa doména nezruší.
- **Odstránenie** (tlačidlo pri doméne, s potvrdením) doménu zruší okamžite: e-maily do nej prestanú ísť. Odstránenie schvaľovanie štyri oči nevyžaduje.
- Pridanie, overenie aj odstránenie sa zapisujú do auditu.

# 8. Ktoré e-maily plugin posiela (jadro PIN)

Tu sú maily o samotnom PINe a 2FA. E-maily o rolách, schvaľovaní, oblastiach a prístupoch len cez PIN sú popísané pri ich kapitolách.

| Predmet (anglicky; v nastavenom jazyku sa preloží) | Kto dostane a kedy | Vypína ho „Bezpečnostné upozornenia“? |
|---|---|---|
| Your PIN was set / was changed / was reset / was recovered | používateľ, po nastavení, zmene, resete správcom, obnove zabudnutého PINu | áno |
| Your PIN was suspended / Your PIN is active again | používateľ, keď správca pozastaví alebo obnoví jeho PIN | áno |
| Your PIN is locked | používateľ, po prekročení počtu zlých pokusov | áno |

| | | |
|---|---|---|
| Your PIN expires soon | používateľ, **raz** pri vstupe do obdobia upozornenia (predvolene 14 dní pred koncom platnosti) | áno |
| Two-factor authentication enabled / disabled / reset | používateľ, pri zmene 2FA | áno |
| Your backup codes were viewed | používateľ, po zobrazení záložných kódov | áno |
| Reset of your PIN / two-factor authentication started | používateľ, keď správca spustí reset (musí ho potvrdiť v NetBoxe) | áno |
| Verification code | 8-miestny kód na zobrazenie záložných kódov bez telefónu (platnosť podľa nastavenia, najviac 5 pokusov, nový kód najskôr po 60 s) | nie |
| PIN recovery code | 8-miestny kód na obnovu zabudnutého PINu | nie |
| Domain verification | kód na overenie domény (na zadanú adresu) | nie |
| Test e-mail | vybraný príjemca zo stránky Mail | nie |

> Vypínač *Bezpečnostné upozornenia e-mailom* ovplyvňuje len prvých sedem riadkov. Kódy, pozvánky, maily o rolách, schvaľovaní, oblastiach a prístupoch len cez PIN idú vždy, keď sú splnené podmienky na začiatku tejto časti (pošta, adresa, overená doména).

# 9. E-maily: keď nejdú

| Príznak | Čo skontrolovať |
|---|---|
| Nikomu nič nechodí | Stránka Mail → karta *Stav*: je *Používa sa* iné než *nenastavené*? Potom **Test pripojenia** a **testovací e-mail**. |
| Test pripojenia hlási chybu | server, port, šifrovanie (port 25 bez šifrovania, 587 STARTTLS, 465 SSL/TLS), prihlasovacie údaje; z NetBoxu servera musí byť SMTP server dostupný. |
| Test prejde, niekomu mail nechodí | V zozname *Používatelia* pozri stĺpec E-mail: *bez e-mailu* alebo *doména* znamená, že adresa chýba alebo jej doména nie je overená. |
| Doménu som pridal, ale nechodia maily | Doména musí byť **overená**: v zozname má byť *overená*, nie *neoverená*. |
| Kód z e-mailu nepríde pri pridaní domény | Pošta nie je nastavená (*No mail server is configured*) alebo je zlá adresa. V audite je *E-mail failed* s chybou. |
| Bezpečnostné upozornenia nechodia, ostatné áno | Vypnutý vypínač *Bezpečnostné upozornenia e-mailom*. |
| Zhrnutia zmien osôb len s PIN-om nechodia | Nebeží `netbox-rq` (posiela ich fronta). |

Všetky odoslané aj zlyhané e-maily sú v *Audit logu* (udalosti *E-mail sent* a *E-mail failed*, bez obsahu e-mailu).

# 10. Môj PIN

**Kto:** každý používateľ, ktorý smie používať PIN. Stránku *Môj PIN* vidí každý prihlásený.
**Kedy:** pri prvom použití, pri vypršaní platnosti (predvolene po 180 dňoch), po resete.
**Závisí od:** povolenie používať PIN (nižšie); 2FA a e-mail v overenej doméne pre obnovu zabudnutého PINu.

## 10.1 Kto smie používať PIN

Rozhoduje nastavenie *Kto smie používať PIN* (Nastavenia → Prístup a pravidlá PINu) a príznak pri každom používateľovi (stránka *Používatelia*):

| Príznak používateľa | Režim „len výslovne povolení“ (predvolený) | Režim „všetci okrem zakázaných“ |
|---|---|---|
| **Povolený** | smie | smie |
| **Zakázaný** | nesmie | nesmie |
| **Podľa predvolenia** (nové účty) | nesmie | smie |

- **Superuser** smie vždy.
- Kto má **rolu** v správe PINov (CORE, vedúci, delegát) alebo čaká na prijatie pozvánky, smie vždy: PIN potrebuje na prijatie a na prácu.
- Kto nesmie, na stránke *Môj PIN* vidí *Povolené používať PIN: Nie – opýtajte sa správcu*.

## 10.2 Stránka Môj PIN

| Položka | Čo ukazuje |
|---|---|
| Povolené používať PIN | Áno / Nie – opýtajte sa správcu |
| PIN | Aktívny / Nenastavený / Vyžaduje sa zmena |
| Naposledy zmenený; Platný do | dátum; počet dní do konca (*rotácia každých N dní*) alebo *vypršal* |
| Posledné úspešné použitie | dátum a čas |
| Zablokovanie | do kedy je účet zablokovaný (po prekročení zlých pokusov) |
| Odomknuté teraz | rozsah odomknutia (alebo *všetko*) |
| Požadovaná dĺžka | N číslic |

Tlačidlá: **Zamknúť teraz** (okamžite zamkne všetko v tejto relácii), **Skúška rotácie** (vynúti zmenu vlastného PINu, aby si si vyskúšal postup), **Zabudnutý PIN**, **Zmeniť PIN** alebo **Nastaviť PIN**. Pod tým je *Posledná aktivita* (čas, udalosť, rozsah).

Upozornenia na stránke: *PIN vyprší o N dní* (so zmenou na jedno kliknutie), *2FA nie je nastavené*, *PIN je pozastavený*, *správca spustil reset*, *pozvánka do roly*.

## 10.3 Nastavenie a zmena PINu

- Len **číslice**, presne taká dĺžka, aká je v nastaveniach (*Dĺžka PINu*, predvolene 6, rozsah 4 až 12). Starý PIN inej dĺžky ostáva platný, kým sa nezmení.

- **Slabé PINy** sa odmietnu (ak je zapnuté *Blokovať slabé PINy*, predvolene áno): opakujúce sa číslice a vzory (`111111`, `121212`, `123123`), súvislé postupnosti nahor alebo nadol (`123456`, `654321`) a vlastný zoznam *Ďalšie blokované PINy* (po jednom na riadok alebo oddelené čiarkou).
- Nikto, ani správca, PIN neprečíta: správca ho môže len resetovať.
- Zmena alebo reset PINu **zruší všetky existujúce odomknutia** používateľa (vo všetkých reláciách).

## 10.4 Odomknutie

Chránená stránka vypýta PIN (*Zadajte PIN*). Po správnom PINe sa odomkne na *Trvanie odomknutia* minút (predvolene 15; 1 až 1440). Pri zapnutom *Predĺžiť odomknutie pri aktivite* (predvolene áno) každé zobrazenie chránenej stránky časovač znovu spustí, takže odomknutie vyprší po nečinnosti. *Rozsah odomknutia*: **jedno odomknutie pre všetko** (predvolené) alebo **osobitné podľa rozsahu** (plugin / oblasť). Voľba *Vyžadovať 2FA pri každom odomknutí* (predvolene vypnutá) vyžaduje aj kód 2FA; používateľ bez 2FA sa vtedy neodomkne.

Odomknutie neplatí, ak je PIN pozastavený, vypršal, alebo používateľ už nesmie používať PIN. Stránka *Test odomknutia* v menu je chránená vlastným rozsahom *test* a slúži na vyskúšanie.

## 10.5 Zlé pokusy a zablokovanie

Po *Max. neúspešných pokusoch* (predvolene 5; 1 až 50) sa účet zablokuje na *Trvanie zablokovania* minút (predvolene 30; až 7 dní). Zlé PINy a zlé kódy 2FA sa počítajú **zvlášť**: správny PIN nevynuluje zlé kódy 2FA a naopak. Počítanie prebieha pod zámkom riadku, takže paralelné hádanie zablokovanie neobíde. Zablokovaný vidí *Príliš veľa neúspešných pokusov. Skúste znova po …*. Odblokuje ho správca (*Zrušiť zablokovanie*) alebo uplynutie času.

## 10.6 Platnosť a rotácia

PIN platí *Max. vek PINu* dní (predvolene 180; 1 až 3650). *Upozornenie pred vypršaním* (predvolene 14 dní) pošle **raz** e-mail a ukáže upozornenie na stránke. Po vypršaní, alebo keď správca vynúti zmenu, treba PIN zmeniť pred ďalším použitím (*Vyžaduje sa zmena*). Pravidelné zmeny odporúča firemná politika, NIST SP 800-63B-4 ich neodporúča: nastav podľa svojich pravidiel.

## 10.7 Zabudnutý PIN (samoobsluha)

1. *Môj PIN → Zabudnutý PIN* (alebo odkaz *Zabudli ste PIN?* na stránke odomknutia) → **Poslať kód**. Prijíma sa len na adresu v overenej doméne. Pošle sa 8-miestny kód; platí *Platnosť kódu na obnovu* minút, najviac 5 pokusov, nový kód najskôr po 60 s.
2. Zadaj kód z e-mailu **a** kód 2FA (alebo záložný kód) a nový PIN. Po úspechu príde e-mail *Your PIN was recovered*.

Obnova sa neponúka (stránka vypíše dôvody), ak: je vypnutá, používateľ nesmie používať PIN, NetBox nevie posielať e-maily, účet nemá e-mail, e-mail nie je v overenej doméne, alebo nie je nastavené 2FA. Vtedy PIN resetuje správca. Obnova **nikdy neobíde 2FA**.

# 11. Dvojfaktorové overenie (2FA)

**Kto:** každý používateľ si ho nastavuje sám (*Môj PIN → Nastaviť 2FA*).

**Kedy:** čo najskôr: bez 2FA nemožno potvrdzovať administratívne akcie ani obnoviť zabudnutý PIN, a rolu (vedúci, delegát, zástupca CORE) nemožno prijať.

**Závisí od:** aplikácia na telefóne s TOTP (Microsoft / Google Authenticator a pod.), balík `segno` (QR kód).

1. *Nastaviť 2FA* → **1. Naskenuj aplikáciou** QR kód (alebo zadaj kľúč ručne: *Nemôžeš skenovať? Zadaj tento kľúč ručne*).
2. **2. Zadaj 6-miestny kód** z aplikácie. Hneď sa zobrazia záložné kódy (*Uložte si tieto kódy teraz*, tlačidlá *Kopírovať* a *Uložil som ich*).

- Kód TOTP sa prijme **len raz** (ochrana proti zopakovaniu).
- **Vypnutie 2FA** (*Môj PIN → Vypnúť 2FA*) vyžaduje PIN a kód 2FA. Bez 2FA nemožno potvrdzovať administratívne akcie ani samoobslužne obnoviť PIN. Príde e-mail *Two-factor authentication disabled*.

## 11.1 Záložné kódy

Jednorazové kódy namiesto aplikácie (napr. po strate telefónu). *Môj PIN → Zobraziť záložné kódy* vyžaduje PIN a buď **kód 2FA**, alebo (bez telefónu) **overovací kód z e-mailu** (*Nemáte telefón? Získajte overovací kód e-mailom*). Kódy sa ukážu len v prehliadači (použité sú označené *použitý*); **Vygenerovať nové kódy** všetky staré zneplatní. Samotné kódy sa nikdy neposielajú e-mailom. Po každom zobrazení príde používateľovi e-mail a zapíše sa do auditu.

## 11.2 Strata telefónu

1. Použi záložný kód.
2. Ak nemáš ani tie: iný správca spustí **Reset 2FA** (používateľ ho potvrdí PINom a nastaví nový telefón).
3. Ak nie je nikto, kto by to mohol urobiť (napr. master bez telefónu a kódov): správca servera spustí `python manage.py userpin_reset_2fa <používateľ>`. 2FA sa odstráni hneď a zapíše sa do auditu. Príkaz s presnými cestami ukazuje *Môj PIN* aj *Používatelia → Núdzovo: príkaz na serveri*.

## 11.3 Potvrdenie administratívnych akcií

Administratívna akcia sa potvrdzuje v okne priamo na stránke (*Potvrďte svoju totožnosť*): *Váš PIN* a *kód 2FA* (6 číslic z aplikácie, alebo záložný kód). Potvrdenie platí *Administratívne okno* minút (predvolene 5; 1 až 60) a akcia pokračuje bez opustenia stránky. Akcie delia na dve úrovne:

| Úroveň | Čo vyžaduje | Príklady |
|---|---|---|
| **Len PIN** (predvolene) | PIN; pri zapnutom *Vyžadovať 2FA aj pre nastavenia* aj 2FA | uloženie Nastavení a Mailu, povoliť/zakázať PIN, zrušiť zablokovanie, vynútiť zmenu PINu, presuny medzi oddeleniami |
| **PIN + 2FA** | vždy aj 2FA | resety, pozastavenie, roly, zrušenie oddelenia |

Ak vypneš *Vyžadovať PIN + 2FA pre administratívne akcie*, stačí PIN. Správa chránených oblastí sa potvrdzuje inak: PIN sa odomkne raz a 2FA sa pýta len každých *2FA sa pýta znova po* hodín (predvolene 8; 1 až 168), nie pri každej zmene.

# 12. Používatelia (stránka PINov)

**Kto ju vidí:** CORE (master a zástupcovia) všetkých; vedúci a delegáti len svoje oddelenie. Bežný používateľ stránku nemá.
**Kedy:** pri správe PINov: povoľovanie, resety, pozastavenie, zrušenie zablokovania.
**Závisí od:** rola správcu (kapitola Roly); potvrdenie PIN alebo PIN + 2FA pred prvou akciou.

Menu **User PIN → Používatelia**, nadpis *PINy používateľov*.

## 12.1 Filtre

- **Hľadanie** (meno, e-mail).
- **Stav:** Všetci / PIN aktívny / Zatiaľ bez PINu / Bez 2FA / Problém s e-mailom (chýba alebo doména) / Zablokovaní / Pozastavení / Nepovolení.
- **Oddelenie:** všetky / bez oddelenia / konkrétne. **Rola:** všetky / master / vedúci / delegát / pozvaný / bez roly.
- **Zobrazenie:** *Zoznam* alebo *Podľa oddelení* (strom: vedúci → delegáti → členovia; farby oddelenia: zelená = vedúci a aspoň 2 delegáti, žltá = chýbajú delegáti, červená blikajúca = chýba vedúci).

## 12.2 Stĺpce

| Stĺpec | Hodnoty |
|---|---|
| Používateľ | účet (+ meno, ak je zapnuté *Zobrazovať meno a priezvisko*); značky *vy*, *master*, *vedúci*, *delegát*, *pozvaný*, *neaktívny* |
| Povolený | *povolený* / *zakázaný* / predvolené (rozhodne režim v Nastaveniach); *Áno* / *Nie* = či môže teraz používať PIN |
| PIN | *Aktívny*, *Nenastavený*, *musí zmeniť*, *pozastavený*, *čaká reset PINu*, *čaká reset 2FA* |
| 2FA | Zapnuté / Vypnuté |
| E-mail | adresa, alebo *bez e-mailu* / *doména* (mimo overených domén): bez toho e-maily nechodia |
| Platný do | dátum alebo *vypršal* (a rotácia každých N dní) |
| Naposledy použitý; Zablokovanie | čas; do kedy je zablokovaný |

## 12.3 Akcie pri používateľovi

| Akcia | Potvrdenie | Čo urobí |
|---|---|---|
| **Povoliť** / **Zakázať** / **Podľa predvolenia** | PIN | nastaví príznak používateľa (viď tabuľku v kapitole Môj PIN). Pri zapnutých štyroch očiach s kategóriou „povoľovanie PINu“ vytvorí žiadosť |
| **Reset PINu** | PIN + 2FA | spustí reset; používateľ ho potvrdí vo vlastnej relácii **kódom 2FA** a nastaví nový PIN. Platí *Platnosť resetu správcom* hodín (predvolene 24). Starý PIN funguje, kým používateľ nepotvrdí |
| **Reset 2FA** | PIN + 2FA | spustí reset; používateľ ho potvrdí **PINom** a nastaví 2FA na novom telefóne |
| **Zrušiť reset** | PIN + 2FA | zruší čakajúci reset |

| | | |
|---|---|---|
| **Pozastaviť / Zrušiť pozastavenie** | PIN + 2FA | PIN okamžite zablokuje (podozrenie z úniku, neprítomnosť), sám, bez druhej osoby; používateľ dostane e-mail |
| **Zrušiť zablokovanie** | PIN | zruší zablokovanie po zlých pokusoch |
| **Vynútiť zmenu** | PIN | pri ďalšom použití musí používateľ zmeniť PIN |
| **Odstrániť PIN** | PIN + 2FA | len pre používateľa **bez 2FA**, ktorý reset potvrdiť nemôže: PIN sa odstráni a pri najbližšej výzve si nastaví nový. Ak má 2FA, treba spustiť reset |

> Reset nikdy neprezradí nový PIN správcovi. Reset začne správca a dokončí ho používateľ sám.

### 12.4 Kto koho smie spravovať

| Správca | Koho smie spravovať |
|---|---|
| Master (superuser) | všetkých okrem seba |
| Zástupca CORE | všetkých okrem mastera, iných zástupcov CORE a seba |
| Vedúci oddelenia | členov svojho oddelenia okrem seba a iných vedúcich |
| Delegát oddelenia | členov svojho oddelenia, ktorí **nemajú žiadnu rolu** |

Nikto nespravuje sám seba (svoj PIN mení v *Môj PIN*). Pri pokuse o zakázanú akciu stránka odpovie: *Delegáti nemôžu spravovať mastera, iných delegátov ani seba.*

### 12.5 Núdzový reset 2FA

V menu *Akcie* pri používateľovi je *Núdzovo: príkaz na serveri (2FA)*: hotový príkaz `userpin_reset_2fa` na spustenie ako root. Použi ho len keď bežný postup (reset potvrdený používateľom PINom) nie je možný. 2FA sa odstráni okamžite a udalosť sa zapíše do auditu.

## 13. Roly: CORE a oddelenia

> **Kto:** master (superuser) vymenúva zástupcov CORE. CORE zakladá oddelenia a vymenúva vedúcich. Vedúci pozývajú delegátov. Delegát spravuje členov bez roly.
>
> **Kedy:** keď PINy nespravuje jeden človek, ale viacero: po jedinej inštalácii stačí master.
>
> **Závisí od:** PIN a 2FA každého nositeľa roly, e-mail v overenej doméne (pozvánka), nastavená pošta, bežiaci `netbox-rq` (pripomienky, vypršanie pozvánok).

```
CORE        master (superuseri) + zástupcovia CORE       spravuje všetkých
Oddelenie   vedúci + delegáti (min. 2) + členovia          PINy členov oddelenia
```

### 13.1 Kto čo vidí a robí

| Menu | Master | Zástupca CORE | Vedúci | Delegát | Používateľ |
|---|---|---|---|---|---|
| Môj PIN, Moje roly | ✓ | ✓ | ✓ | ✓ | ✓ |
| Používatelia | všetci | všetci | vlastné oddelenie | vlastné oddelenie | – |

| | | | | | |
|---|---|---|---|---|---|
| Oddelenia | všetko | všetko | vlastné: pozvať delegátov, odovzdať, žiadať o presun | vlastné: čítať, s druhým delegátom pozvať a odovzdať | – |
| Audit log, Schvaľovania | všetko | všetko | vlastné oddelenie | vlastné oddelenie | – |
| Nastavenia, Mail | úprava | čítanie (úprava s oprávnením) | – | – | – |
| CORE (zástupcovia) | ✓ | – | – | – | – |

Kto koho smie spravovať (akcie na stránke Používatelia) je v kapitole Používatelia.

## 13.2 Pozvánka na rolu

Každá rola (zástupca CORE, vedúci, delegát, dočasný vedúci, náhrada) je **pozvánka**:

1. Pozývajúci vyberie používateľa a **platnosť pozvánky: 12, 24, 36 alebo 48 hodín** (inú hodnotu stránka odmietne).
2. Pozvanému príde e-mail s vysvetlením roly a zodpovednosti, odkazom a kódom, a upozornenie vo zvončeku.
3. Pozvaný otvorí pozvánku. Ak ešte nemá PIN alebo 2FA, stránka ho najprv odošle ich **nastaviť** (*Najprv nastavte* PIN a 2FA) a potom sa vráti.
4. Pozvaný pozvánku **prijme** kódom z e-mailu, svojím PINom a kódom 2FA (kód sa dá zadať najviac 5-krát) alebo ju **odmietne**. Až prijatím rola začne platiť.

**Kto môže byť pozvaný:** aktívny používateľ, ktorý nie je superuser (master rolu nepotrebuje), nemá zakázaný PIN, **má e-mail v overenej doméne a pošta je nastavená** (inak by pozvánka nedorazila; stránka to odmietne a napíše prečo), nemá už rovnakú rolu ani otvorenú pozvánku. Zástupca CORE nemôže mať rolu v oddelení; človek v inom oddelení musí byť najprv presunutý. **Delegát sa dá pozvať až keď má oddelenie vedúceho**: najprv vedúci, potom delegáti. Ak pozvánka vyprší, dá sa poslať znova (*Poslať znova*) alebo zrušiť.

## 13.3 Minimum a zánik roly

- **Minimum:** so zapnutými štyrmi očami aspoň **2 zástupcovia CORE**; každé oddelenie **vedúci a aspoň 2 delegáti**.
- **Odstúpenie:** nositeľ roly ju vzdá v *Moje roly*. Pod minimum rola ostáva v platnosti (*odstupuje*), kým neprijme náhrada. Nadriadení sa dozvedia e-mailom (delegáta vedúci, vedúceho CORE, zástupcu CORE master).
- **Odstránenie / výmena** (tlačidlo *Odstrániť / nahradiť*): pod minimum len spolu s náhradou, stará osoba ostáva, kým náhrada neprijme. **Riadny vedúci** sa končí hneď (oddelenie dočasne spravuje CORE, kým nový vedúci pozvánku neprijme).
- Oddelenie bez aktívneho vedúceho hlási *The department has no active head – CORE manages it until a head accepts the invitation.*

## 13.4 Zástupcovia CORE (stránka CORE (zástupcovia), len master)

- **Pozvať zástupcu** (s voľbou *Môže upravovať nastavenia*).
- Pri zástupcovi: **Povoliť nastavenia** / **Len na čítanie** (prepne, či smie meniť Nastavenia a Mail), **Odstrániť / nahradiť**, **Poslať znova**, **Zrušiť**. Dole je *História*.
- Stránka ukazuje počet aktívnych zástupcov a či sú zapnuté štyri oči (potrebujú aspoň 2).

- Zástupca vidí všetkých používateľov a oddelenia (po potvrdení PIN + 2FA), zakladá oddelenia a vymenúva vedúcich. Nespravuje mastera ani iných zástupcov.

### 13.5 Oddelenia

Stránka **Oddelenia**: tabuľka (oddelenie, vedúci, delegáti, členovia; *bez vedúceho – spravuje CORE*), čakajúce presuny na rozhodnutie, počet aktívnych používateľov bez oddelenia (spravuje ich len CORE) a formulár **Nové oddelenie** (názov musí byť jedinečný). Detail oddelenia:

| Časť | Čo robí a kto |
|---|---|
| **Vedúci a delegáti** | tabuľka (osoba, rola, stav; *dočasný vedúci* s „namiesto …“); *Pozvať vedúceho* / *Nahradiť vedúceho* (CORE); *Pozvať delegáta* (vedúci, CORE; delegát potrebuje druhého delegáta, vedúceho alebo CORE na potvrdenie) |
| **Dočasné odovzdanie vedúceho** | pozvánka člena oddelenia na **dočasného vedúceho do dátumu** (dovolenka, choroba). Člen ju musí **prijať**. Vedúci a CORE bez obmedzenia dĺžky; **dvaja delegáti spolu najviac na 30 dní**, keď vedúci nie je dostupný. Naraz môže byť len jedno. Celé oddelenie dostane e-mail a deň vopred pripomienku. Po dátume sa práva vrátia sami (systémová úloha každých 5 minút). Predčasne: *Ukončiť odovzdanie* |
| **Členovia** | tabuľka členov (PIN, 2FA, e-mail, rola); odkaz *Spravovať PINy členov* |
| **Presuny** | pozri nižšie |
| **Zrušiť oddelenie** | CORE (PIN + 2FA). Všetky roly sa ukončia, členovia dostanú e-mail; ich vlastný PIN to neovplyvní |
| **História** | zmeny rolí v oddelení |

### 13.6 Presuny medzi oddeleniami

- **CORE presúva priamo.** Vedúci o presun **žiada** (*Žiadať o presun*); o žiadosti rozhoduje vedúci druhého oddelenia (u ľudí bez oddelenia CORE; ak druhé oddelenie nemá vedúceho, rozhoduje CORE).
- Žiadosť platí *Platnosť žiadosti* minút (predvolene 24 hodín); rozhodujúci ju **schváli** alebo **zamietne**, žiadateľ ju môže **zrušiť**. Rozhodujúci dostane e-mail a upozornenie. Pre človeka môže čakať len jeden presun.
- Presunutý, obaja vedúci a obe oddelenia sa dozvedia e-mailom. Delegáta potrebného do minima nemožno presunúť pred príchodom náhrady.
- Člen sa dá priradiť k oddeleniu aj z formulára *Dostať niekoho do tohto oddelenia*.

### 13.7 Moje roly

Každý vidí, do ktorého oddelenia patrí, svoje roly (čo to znamená a aká je zodpovednosť), čakajúcu pozvánku, upozornenie o dočasnom odovzdaní a stav odstúpenia, a môže rolu **vzdať**. Rola sa synchronizuje do oprávnení NetBoxu s názvami `User PIN: …`: neupravuj ich ručne.

## 14. Schvaľovanie „štyri oči“

**Kto zapína:** ten, kto môže meniť Nastavenia (master, zástupca CORE s oprávnením).
**Kedy:** keď má citlivú zmenu potvrdiť druhá osoba.
**Závisí od:** aspoň **dvaja aktívni zástupcovia CORE** s PINom a 2FA; bez nich sa zapnúť nedá.

## 14.1 Zapnutie a kategórie

Nastavenia → *Schvaľovanie „štyri oči“* (predvolene vypnuté). Po zapnutí sa vyberie, na čo sa vzťahuje:

| Kategória | Predvolene | Ktoré akcie vytvoria žiadosť |
|---|---|---|
| … pre roly (CORE, vedúci a delegáti) | áno | pozvať do roly, ukončiť alebo nahradiť rolu, zmeniť oprávnenie zástupcu upravovať nastavenia, zrušiť oddelenie |
| … pre nastavenia a mailové nastavenia | áno | uloženie Nastavení, uloženie Mailu, pridanie povolenej domény |
| … pre povoľovanie / zakazovanie PINu | nie | Povoliť / Zakázať / Podľa predvolenia pri používateľovi |

- **Zapnutie** vyžaduje aspoň 2 aktívnych zástupcov CORE. Informuje sa zástupcov (e-mail *Four-eyes approval switched on*).
- **Vypnutie** sa **nedá**, kým existuje oddelenie. Vypnutie vyžaduje dvoch ľudí a **ukončí delegovanie CORE**: zástupcovia sa dozvedia e-mailom a odvtedy spravujú len svoj vlastný PIN.

## 14.2 Priebeh žiadosti

1. Žiadateľ urobí zmenu: zobrazí sa žiadosť *Žiadosť štyroch očí č. N* s dôvodom. Žiadateľ ju potvrdí PINom + 2FA (*Potvrdiť svoju žiadosť*).
2. Iná oprávnená osoba dostane upozornenie vo zvončeku a e-mail. Oprávnení sú: master a zástupcovia CORE; pri žiadosti oddelenia aj jeho vedúci a delegáti.
3. Otvorí *Schvaľovania* (alebo odkaz) a **Potvrdí** alebo **Zamietne** svojím PINom + 2FA. Nemožno hlasovať dvakrát.
4. Stránka žiadosti sa sama obnovuje a obaja vidia potvrdenia (kto, čas, IP). Hneď po druhom potvrdení sa zmena vykoná.

- Žiadosť platí *Platnosť žiadosti* minút (predvolene 1440 = 24 h; 5 až 10080) a potom vyprší.
- Žiadateľ ju môže **zrušiť**. Zamietnutie sa oznámi e-mailom.
- **Break-glass** (predvolene vypnuté, *Povoliť break-glass pre mastera*): superuser smie žiadosť v nevyhnutnom prípade vykonať **sám** s dôvodom (*Vykonať sám*). Všetci správcovia a delegáti dostanú e-mail a v audite je to označené.

Stránka **Schvaľovania (štyri oči)**: *Čakajúce* (zmena, žiadateľ, potvrdené, platí do; *Potvrdiť*/*Otvoriť*) a *História* (zmena, žiadateľ, potvrdil, stav, dokončené). Ak je schvaľovanie vypnuté, stránka to hlási.

# 15. Audit log

**Kto ho vidí:** CORE (master a zástupcovia) všetko; vedúci a delegáti len udalosti ľudí zo svojho oddelenia a svoje.
**Kedy:** pri vyšetrovaní, kto čo urobil a kedy.
**Závisí od:** nič: zapisuje sa vždy.

Menu **User PIN → Audit log** (*Audit log PINov*). Záznamy sa len pridávajú (nedajú sa meniť) a **nikdy neobsahujú PIN, hash ani kód**. Stránka má 50 záznamov na stranu a filtre: *Používateľ* (text: účet alebo ten, kto akciu urobil) a *Udalosť* (výber z typov). Stĺpce: *Čas*, *Používateľ*, *Udalosť*, *Kto*, *Rozsah*, *Detail*.

### 15.1 Čo sa zapisuje

| Oblasť | Udalosti |
|---|---|
| PIN | nastavený, zmenený, resetovaný, overený, nesprávny, zablokovaný, odmietnutý (zablokovaný), zrušené zablokovanie, vynútená zmena, pozastavený, obnovený, zamknutý, nepovolený |
| 2FA | zapnuté, vypnuté, resetované, nesprávny kód, použitý záložný kód, nové záložné kódy, zobrazené záložné kódy |
| Potvrdenie a obnova | potvrdenie (úspech aj zlyhanie), poslaný/správny/nesprávny kód na obnovu, poslaný overovací kód e-mailom, reset spustený / dokončený / zrušený |
| E-mail | e-mail odoslaný / zlyhal, doména pridaná / overená / zlyhalo overenie / odstránená |
| Roly a oddelenia | pozvanie, prijatie, odmietnutie, vypršanie, odstupovanie, ukončenie, dočasné odovzdanie, návrat, zástupca pridaný/odobraný/zmenený, oddelenie vytvorené/zrušené, člen pridaný/odobraný, presun (žiadosť, schválenie, zamietnutie) |
| Schvaľovanie | žiadosť, potvrdenie, zamietnutie, zrušenie, vykonanie, break-glass |
| Nastavenia a kľúče | zmena nastavení (aj výnimiek a ochrany), rotácia kľúča, chyby |
| Oblasti | oblasť vytvorená/zmenená/zmazaná, správca pridaný/odobraný, žiadosť, udelenie, zamietnutie, odvolanie, zrušenie, odmietnutý prístup, strážca pridaný/odobraný, ochrana zapnutá/vypnutá, **zmena objektu v chránenej oblasti** (používateľom v skupine; nie strážcom ani osobami len s PIN-om) |
| Osoby len s PIN-om | vytvorenie, pozvánka, prihlásenie, nesprávny PIN, nový PIN, reset, odvolanie, zmazanie, zablokovanie a odblokovanie, pravidlá, žiadosť o odblokovanie, koniec platnosti a upozornenie naň, správca, pracovný čas |

# 16. Nastavenia

**Kto ich vidí:** CORE (master a zástupcovia). Ostatní ich nemajú. (Ak existujú strážcovia aj aktívni zástupcovia CORE, superuser, ktorý nie je zástupca CORE, ich nevidí.)

**Kto môže meniť:** master a zástupca CORE s oprávnením *Môže upravovať nastavenia*. Ostatní vidia stránku s nápisom *Iba na čítanie*.

**Potvrdenie:** uloženie vyžaduje PIN (a 2FA pri zapnutom *Vyžadovať 2FA aj pre nastavenia*). So zapnutými štyrmi očami a kategóriou „nastavenia“ vytvorí žiadosť.

**Kedy:** po inštalácii a pri zmene firemnej politiky.

Menu **User PIN → Nastavenia** (*Nastavenia PINu*). Stránka má karty: Všeobecné, Prístup a pravidlá PINu, Rotácia, Odomknutie, Ochrana, Schvaľovanie štyri oči, Chránené oblasti a dole *Šifrovací kľúč* (aktívny kľúč, odtlačok, nastavené kľúče). **Pošta** (SMTP, domény, upozornenia, obnova zabudnutého PINu) je na osobitnej stránke *Mail*; **Zakázať všetko, čo nie je povolené** a ďalšie voľby ochrany sú na stránke *Chránené oblasti*; pravidlá osôb len s PIN-om sú na stránke *Ľudia len s PIN-om*.

### 16.1 Všeobecné

| Voľba | Predvolené | Význam |
|---|---|---|
| Jazyk | English | jazyk stránok pluginu a e-mailov: *English* alebo *Slovenčina* |

| | | |
|---|---|---|
| Zobrazovať meno a priezvisko | áno | meno vedľa účtu (Používatelia, CORE, Oddelenia, príjemcovia e-mailov) |

## 16.2 Prístup a pravidlá PINu

| Voľba | Predvolené | Význam |
|---|---|---|
| Kto smie používať PIN | len výslovne povolení | *Len výslovne povolení* alebo *Všetci, okrem zakázaných*. Povolenie pre jednotlivca je na stránke Používatelia. Superuseri smú vždy |
| Dĺžka PINu | 6 | počet číslic, 4 až 12. Staré PINy inej dĺžky platia, kým sa nezmenia |
| Blokovať slabé PINy | áno | odmietne opakované číslice (111111), postupnosti (123456) a vzory (121212) |
| Ďalšie blokované PINy | prázdne | vlastný zoznam; jeden na riadok alebo oddelené čiarkou |

## 16.3 Rotácia

| Voľba | Predvolené | Význam |
|---|---|---|
| Max. vek PINu (dni) | 180 | 1 až 3650; po uplynutí treba PIN zmeniť |
| Upozornenie pred vypršaním (dni) | 14 | 0 až 365; raz pošle e-mail a ukáže upozornenie |

## 16.4 Odomknutie

| Voľba | Predvolené | Význam |
|---|---|---|
| Trvanie odomknutia (minúty) | 15 | 1 až 1440 |
| Predĺžiť odomknutie pri aktivite | áno | každé zobrazenie chránenej stránky obnoví časovač (vyprší po nečinnosti) |
| Rozsah odomknutia | jedno odomknutie pre všetko | alebo osobitné odomknutie podľa rozsahu (plugin / oblasť) |
| Vyžadovať 2FA pri každom odomknutí | nie | PIN aj kód 2FA |

## 16.5 Ochrana

| Voľba | Predvolené | Význam |
|---|---|---|
| Max. neúspešných pokusov | 5 | 1 až 50; PIN a 2FA sa počítajú zvlášť |
| Trvanie zablokovania (minúty) | 30 | 1 až 10080 (7 dní) |
| Vyžadovať PIN + 2FA pre administratívne akcie | áno | povoliť/zakázať, reset, vynútiť zmenu, nastavenia a delegáti vyžadujú čerstvé potvrdenie; keď je vypnuté, stačí PIN |
| Vyžadovať 2FA aj pre nastavenia | nie | vypnuté: Nastavenia, Mail a každodenné akcie vyžadujú len PIN. Resety, pozastavenie a roly vždy PIN + 2FA |
| Administratívne okno (minúty) | 5 | 1 až 60; ako dlho platí potvrdenie |
| 2FA sa pýta znova po (hodiny) | 8 | 1 až 168; pri správe chránených oblastí |
| Platnosť resetu správcom (hodiny) | 24 | 1 až 336; ako dlho má používateľ na potvrdenie resetu |

### 16.6 Schvaľovanie štyri oči

| Voľba | Predvolené | Význam |
|---|---|---|
| Schvaľovanie štyri oči | nie | zapnutie vyžaduje 2 aktívnych zástupcov CORE; vypnúť sa nedá, kým existuje oddelenie |
| … pre roly | áno | pozri kapitolu Schvaľovanie |
| … pre nastavenia a mailové nastavenia | áno | vrátane pridania domény |
| … pre povoľovanie / zakazovanie PINu | nie | |
| Platnosť žiadosti (minúty) | 1440 | 5 až 10080; platí aj pre žiadosti o presun |
| Povoliť break-glass pre mastera | nie | superuser môže žiadosť vykonať sám s dôvodom |

Uloženie hlási chybu, ak zapínaš štyri oči bez dvoch aktívnych zástupcov CORE (*At least two active CORE deputies with PIN and 2FA are needed*) alebo ich vypínaš pri existujúcom oddelení.

### 16.7 Chránené oblasti

| Voľba | Predvolené | Význam |
|---|---|---|
| Chrániť oblasti a objekty | nie | oblasti definované na stránke Chránené oblasti začnú platiť. Pluginy s vlastnou „PIN integráciou“ sú chránené, keď je zapnutý ich vlastný prepínač, aj keď je táto voľba vypnutá. **Vypnúť sa nedá, kým sú aktívne oblasti so správcami** |

### 16.8 Čo je na iných stránkach

| Voľba | Kde |
|---|---|
| Bezpečnostné upozornenia e-mailom; Samoobslužná obnova; Platnosť kódu na obnovu | Mail |
| Zakázať všetko, čo nie je povolené; Čo sa nepovolené zobrazuje (A / B); Používatelia smú žiadať o prístup; Používatelia smú vytvoriť vlastný API kľúč | Chránené oblasti (karta Ochrana) |
| Adresa prihlásenia osôb len s PIN-om; zlé PINy; e-maily; pracovný čas | Ľudia len s PIN-om |

## 17. Chránené oblasti

**Kto:** stránku *Chránené oblasti* vidí strážca ochrany, správca úseku a (kým nie je strážca) CORE / master. Oblasti zakladá a ciele pridáva len **strážca** (kým nie je, tak CORE / master). Skupiny, polia a členov spravuje strážca alebo správca príslušného úseku.

**Kedy:** keď má určitá časť NetBoxu (aplikácia alebo typ objektu, napr. DCIM › Device, Tenancy › Tenant) vidieť a meniť len ten, kto dostal prístup.

**Závisí od:** zapnutá ochrana (kapitola Ochrana), aspoň jeden strážca, správcovia úsekov s PINom a 2FA, a pre žiadosti pošta (kapitola E-maily).

## 17.1 Základná myšlienka

Oblasť chráni **typ objektu** (`dcim.device`) alebo celú **aplikáciu** (`dcim`). V chránenej oblasti **nikto nie je boh**: rolu ani oprávnenia používateľa v NetBoxe plugin vôbec nezohľadňuje, rozhoduje **skupina**, do ktorej ho zaradil strážca alebo správca úseku, aj keď ide o superusera. Dvere (položka menu, karta) vidí každý; kto nemá kľúč, je pri vstupe odmietnutý a dozvie sa, kto prístup spravuje (stránka „Táto oblasť je chránená“). Do oblasti nemožno vložiť citlivé aplikácie (`users`, `auth`, `core` a pod.) inak ako strážca.

## 17.2 Stránka Chránené oblasti

- **Karta Ochrana**: stav ZAP/VYP a prepínač (kapitola Ochrana).
- **Správcovia ochrany** (strážcovia), **Výnimky**, **Čo používatelia vidia**: kapitola Ochrana.
- **Čo je nastavené**: zoznam chránených aplikácií a typov objektov. Pri každom je počet členov, skupín, správcov (*zatiaľ bez správcu*) a tlačidlá *Otvoriť* a *Zmazať* (*Odstrániť ochranu tohto typu objektu? Jeho skupiny a prístupy sa zmažú.*).
- **Pridať aplikáciu alebo typ objektu**: vyber zo zoznamu a *Pridať*. Pridanie len pripraví štruktúru: **nikto nedostane prístup**, kým nevytvoríš skupinu a nezaradíš do nej používateľov. Kým oblasť nemá správcu, vidia ju len strážcovia.
- Hore je počet *žiadostí o prístup čakajúcich na rozhodnutie*. Ak je ochrana vlastných oblastí vypnutá, stránka to hlási (*Nastavenia → Chránené oblasti*); oblasti pluginov s „PIN integráciou“ chránia hneď, ako sa integrácia plugin zapne.

## 17.3 Detail oblasti

| Časť | Čo je to |
|---|---|
| **Čaká na rozhodnutie** | žiadosti o prístup (používateľ, kedy žiadal, čo žiadal, prečo, čo presne). Tlačidlá *Rozhodnúť* a *Zamietnuť* |
| **Skupiny** | pomenované sady práv. *Nová skupina* → názov → *Vytvoriť skupinu*; otvor ju a nastav práva, záložky, polia a členov |
| **Používatelia** | kto je v ktorej skupine, *do kedy* (alebo *bez časového limitu*) a tlačidlo *Odobrať* |
| **Správcovia úsekov** | kto rozhoduje o oblasti; pozri kapitolu Správcovia úsekov |
| **Nastavenia oblasti** | názov, popis, *Najdlhší dočasný prístup (hodiny)* (predvolene 24, najviac 720), *Aktívny*, *Čo nie je povolené* (podľa nastavení / A dvere / B skryté): platí pre položky menu a karty tejto oblasti. Tlačidlo *Zmazať oblasť*: objekty sa vrátia pod oprávnenia NetBoxu |

Skupina je pre jeden typ objektu. Používateľ je v **jednej skupine na typ**: pridanie do inej ho presunie a odchod z poslednej znamená žiadny prístup. Prístup môže byť dočasný (*do*) alebo bez limitu; dočasný trvá 1 hodinu až *Najdlhší dočasný prístup* hodín. Používateľ môže svoj prístup sám ukončiť (*Môj prístup → Ukončiť môj prístup*); ostatným ho odoberá strážca alebo správca.

## 17.4 Skupina: práva

Stránka skupiny (*Skupina*) má tieto časti:

| Časť | Voľby |
|---|---|
| **Názov skupiny** | text |
| **Prístup** | *Nevidí* / *Len čítať* / *Čítať a zapisovať*. Kto smie zapisovať, smie aj čítať |

| | |
|---|---|
| Ďalšie práva | *Smie mazať*; *Smie importovať* (potrebuje aj zapisovanie, tlačidlo Import); *Smie exportovať*. Bez nich sa tlačidlá Import / Export nevykreslia a stránky odpovedia „bez prístupu“ |
| Práva pluginu | ak plugin definuje vlastné práva (napr. *config*), ponúknu sa ako ďalšie zaškrtávacie polia |
| **Zákaz** (*vyhráva nad každým povolením*) | právo, ktoré skupina nikdy nemá, aj keď by ho dostala inak |
| **Záložky stránky** | pri každej systémovej záložke detailu (Interfaces, Config Context, Changelog …) *Skryté* / *Viditeľné*. Hlavná stránka je vždy povolená. Záložky pluginu sa riadia oblasťou toho pluginu |
| **Členovia** | *Pridať používateľov do skupiny*; tlačidlo *Odobrať* |

Záložka, ktorá vypisuje **iné objekty** (rozhrania zariadenia), potrebuje právo aj na ich typ; pri zapnutej ochrane musí byť aj ten typ v nejakej oblasti.

## 17.5 Skupina: záznamy, ktoré vidí

| Voľba | Význam |
|---|---|
| *Nenastavené (nevidí žiadny záznam)* | východisko: členovia nevidia žiadny riadok |
| *Všetky záznamy* | členovia vidia všetky riadky tohto typu |
| *Len podľa podmienok* | vidia len riadky, ktoré vyhovujú podmienkam |

- **Povolené**: viac hodnôt jednej podmienky sú alternatívy (*agg* alebo *core*); viac podmienok musí platiť **všetky naraz**. Bez podmienky skupina nevidí nič.
- **Zakázané**: záznamy, ktoré vyhovujú niektorej z týchto podmienok, sa **nikdy nezobrazia**, nech ich povoľuje čokoľvek.
- Podmienka = *pole* + *operátor* + hodnota. Operátory: *je*, *nie je*, *obsahuje*, *neobsahuje*, *začína na*, *je jedno z*, *nie je jedno z*. Pri poli s výberom alebo väzbou sa hodnoty vyberajú zo zoznamu.

## 17.6 Polia

Pre skupinu (alebo pre každého v oblasti) a typ objektu je každé pole:

| Režim | Význam |
|---|---|
| *Podľa práv* (predvolené) | kto smie pridávať alebo meniť, vidí a zapisuje každé pole; kto len číta, číta |
| *Skryté* | pole sa používateľovi nezobrazí |
| *Len na čítanie* | vidí, nemôže meniť |
| *Čítať a zapisovať* | vidí aj mení |

- Stránka **Polia** (*Pravidlá pre* skupinu alebo používateľa + typ objektu): rozbaľ skupinu a nastav pole po poli, alebo naraz *Nastaviť všetky zobrazené polia* (pôsobí na polia, ktoré nechalo hľadanie), potom *Uložiť pravidlá*.
- Voľba **Skryté pred všetkými v oblasti** skryje pole pred každým v oblasti vrátane správcov.
- **Podmienka na hodnoty poľa** (*Hodnoty musia obsahovať*, alebo tlačidlom *Podmienky*: *obsahuje*, *začína na*, *je jedno z*; viac hodnôt ako štítky) obmedzí, čo smie používateľ vybrať: pri **vlastných poliach prepojených na iné objekty** (napríklad zariadenie, ktorého názov obsahuje `PRINTER`), pri **výberových vlastných poliach** (select a multiselect) a pri **poliach s pevným zoznamom** (napríklad stav zariadenia). **Rozbaľovací zoznam ponúkne len povolené hodnoty** a hodnota

mimo podmienky sa odmietne aj pri uložení vo formulári aj cez REST API. Ak sa tá istá sada hodnôt používa vo viacerých poliach, zoznam ukáže hodnoty, ktoré povoľuje ktorékoľvek z nich (a všetky, ak jedno z polí podmienku nemá).
- Skryté vlastné pole **si ponechá uložené dáta** (uloženie objektu ich nikdy nevymaže).
- **Pomocné polia formulára.** Niektoré polia vo formulári nie sú polia modelu, napríklad *Owner group* pri poli *Owner* (len zužuje výber vlastníkov, nič neukladá). V zozname polí nie sú; riadia sa poľom, ku ktorému patria: skrytím alebo zamknutím *Owner* sa skryje alebo zamkne aj *Owner group*.

| Kde sa pravidlá uplatnia | vlastné polia | polia modelu |
|---|---|---|
| detail objektu | skryté / filter hodnôt | **nepokryté** (NetBox kreslí pevné polia ručne) |
| formuláre úprav | odstránené / zakázané; výber sa zúži | odstránené / zakázané |
| tabuľky | stĺpec odstránený | stĺpec odstránený |
| REST API | vynechané / filter / zápis ignorovaný | vynechané / len čítanie |

## 17.7 Záložky detailu a karty

Stránka *Záložky detailu* určuje, ktoré záložky detailu objektu (Interfaces, Config Context, Changelog …) smie používateľ otvoriť. Hlavná stránka je vždy povolená. Nový prístup povoľuje len hlavnú stránku. Správca úseku otvorí každú záložku.

## 17.8 Žiadosť o prístup

1. Používateľ, ktorému je cesta zatvorená, vidí stránku „Táto oblasť je chránená“ (kto prístup spravuje, čo sa zablokovalo, čo tu môže robiť: *Zmeniť heslo*, *Môj PIN*, *Moje API kľúče*). Zaškrtne **čo potrebuje** (zobraziť / pridať / zmeniť / zmazať), napíše **prečo** a **čo presne** (sekcia, skupina, objekt) a stlačí *Požiadať o prístup*.
2. E-mail s odkazom dostane **správca úseku a strážcovia**; ak oblasť pre typ ešte neexistuje, len strážcovia. Odkaz otvorí stránku *Žiadosť o prístup* (kto, čo, prečo, kedy).
3. Rozhodujúci vyberie **skupinu**, do ktorej používateľa zaradí (alebo *Nová skupina* s názvom), **práva na udelenie** a **na ako dlho**, a stlačí *Schváliť* alebo *Zamietnuť*. Ak pre typ ešte neexistuje oblasť, schválenie ju vytvorí (bez správcov: ich treba určiť ručne) a používateľa pridá.
4. Žiadateľ dostane e-mail o rozhodnutí (aj strážcovia a správca). Čakajúcu žiadosť môže **zrušiť** v *Môj prístup → Moje žiadosti*.

- O vlastnej žiadosti nikto nerozhoduje. Žiadať môže len jedna čakajúca žiadosť na používateľa, oblasť a typ.
- Žiadosti sa dajú vypnúť (*Používatelia smú žiadať o prístup*): vtedy žiadosť robia len správcovia. Osoby len s PIN-om žiadať nemôžu.
- Používateľ bez PINu je pri vstupe poslaný vytvoriť si ho (bez 2FA) a potom pokračuje.

## 17.9 Môj prístup

Menu *Môj prístup*: **Môj prístup k chráneným oblastiam** (oblasť, profil, do kedy, *Ukončiť môj prístup*), úseky, ktorých si správcom, a **Moje žiadosti** (oblasť, kedy, stav, *Zrušiť*). Hore je počet žiadostí čakajúcich na tvoje rozhodnutie.

### 17.10 Čo sa vynucuje

| Kde | Ako |
|---|---|
| Stránky NetBoxu (zoznamy, detaily, pridať/upraviť/zmazať, hromadné akcie, stránky pluginov) | middleware odmietne bez práva (*zobraziť* na čítanie, *pridať / zmeniť / zmazať* podľa druhu stránky); PIN musí byť odomknutý |
| Riadky | obalené `RestrictedQuerySet.restrict`: v chránenej oblasti vráti riadky, ktoré povoľuje skupina (bez nej žiadne): zoznamy, detaily, REST API, rozbaľovacie zoznamy |
| REST API a GraphQL | pre prihlásenú reláciu odmietnuté bez práva (403 JSON); hlavička `Authorization` pri relácii nič nemení. Požiadavka s **platným API tokenom** je mimo PIN ochrany a riadi sa len oprávneniami NetBoxu (pozri kapitolu Ochrana a výnimky) |
| Menu a karty | `has_perm` odpovedá podľa prístupov z PINu |
| Záznam zmien, žurnál, prílohy | nikdy neukážu riadky objektov, ktoré používateľ nesmie vidieť |

**Nepokryté:** filtre v zoznamoch (`?cf_nazov=…`), exporty, pevné polia detailu a zoznamy miešajúce viac typov. Kto má root / DB prístup na server, obíde akýkoľvek plugin: odpoveďou je audit, nie technický zámok.

### 17.11 Oblasť pluginu

Plugin si môže zaregistrovať vlastnú oblasť (`areas.register(...)`) s vlastnými právami a profilmi. Je chránená, keď je zapnutý jeho prepínač „PIN integrácia“, aj bez globálneho *Chrániť oblasti a objekty*. Pozri kapitolu Použitie z iného pluginu.

## 18. Globálna ochrana (ZAP / VYP) a strážcovia

**Kto:** len **strážcovia ochrany**. Kým nie je žiadny strážca, prvého vymenuje CORE / master.

**Kedy:** keď chceš, aby sa všetko, čo žiadna skupina nepovoľuje, zakázalo; vypína sa v núdzi alebo pri údržbe.

**Závisí od:** aspoň jeden strážca s PINom a 2FA. Bez strážcu sa ochrana nedá zapnúť.

Karta **Ochrana** je hore na stránke *Chránené oblasti*.

### 18.1 ZAP a VYP

| Stav | Čo platí |
|---|---|
| **ZAP** | všetko, čo žiadna skupina nepovoľuje, je zakázané **všetkým okrem strážcov a výnimiek**. Osoby len s PIN-om vidia len svoje skupiny. Týka sa to každej cesty: zoznamy, detaily, REST API, GraphQL, vyhľadávanie, widgety, menu a tlačidlá. Superuser, ktorý nie je strážca, nevidí Používateľov, Skupiny, Oprávnenia, Úlohy, Pozadie… Vlastný profil, záložky, notifikácie a predvoľby ostávajú otvorené, ale len vlastné |
| **VYP** | všetci pracujú len podľa oprávnení NetBoxu. Osoby len s PIN-om môžu iba zmeniť svoj PIN a dozvedia sa, že funkciu vypol správca |

Tlačidlá *Zapnúť ochranu* / *Vypnúť ochranu* vidí a stláča len strážca. Zmena sa zapíše do auditu a pošle sa e-mail ostatným strážcom.

## 18.2 Správcovia ochrany (strážcovia)

- Karta **Správcovia ochrany**: zoznam, *Odobrať* a *Určiť ďalšieho správcu*. Kým nie je žiadny, stojí *Určiť prvého správcu (zapne ochranu)*: **vymenovanie prvého strážcu ochranu zapne**.
- Strážca musí mať **PIN a 2FA**, účet musí byť aktívny a nesmie to byť osoba len s PIN-om. Po vymenovaní dostane e-mail *You are a protection keeper*.
- Strážca je **vyňatý zo zákazu** (platia preňho oprávnenia NetBoxu), nemôže si vypnúť 2FA a **nemôže odísť sám**: musí ho prevziať iný strážca.
- **Posledného strážcu nemožno odobrať.** Ak sa jeho účet zmaže, ochrana sa vypne a nedá sa zapnúť, kým strážca nie je.
- **Strážca môže všetko**: oblasti, typy objektov, správcov úsekov, výnimky, prepínač ZAP/VYP a všetky prístupy len cez PIN. Obmedzenia pre výnimky a správcov sa naňho nevzťahujú.

## 18.3 Čo používatelia vidia

Karta **Čo používatelia vidia** (uloží sa tlačidlom *Uložiť*):

| Voľba | Predvolené | Význam |
|---|---|---|
| **Čo nie je povolené** | A – dvere | **A – dvere:** používateľ vidí všetko a PIN zablokuje, čo nie je povolené, upozornením (s možnosťou žiadosti). **B – skryté:** používateľ, ktorý nie je v žiadnej skupine, nevidí nič (len zmenu hesla a PINu); v skupine vidí len to, čo skupina povoľuje; žiadne API v prehliadači. Každá oblasť si môže zvoliť vlastné (Nastavenia oblasti) Osoby len s PIN-om vždy žijú v režime B, nech je v nastaveniach akýkoľvek. |
| **Používatelia smú žiadať o prístup** | áno | vypnuté: žiadosti robia len správcovia (nie je stránka ani tlačidlo) |
| **Používatelia smú vytvoriť vlastný API kľúč** | nie | kľúč pracuje s oprávneniami NetBoxu a PIN ho neposudzuje: superuser s kľúčom prečíta všetko cez skript. Povoľ len pri užších oprávneniach. Používateľ potom vidí len **vlastné** kľúče |

> Existuje aj skrytá voľba *Na koho sa ochrana vzťahuje*: predvolene **len ľudia s PINom** (osoby len s PIN-om a používatelia v skupine alebo správcovia úsekov; ostatní pracujú podľa oprávnení NetBoxu a plugin nevidia). V rozhraní sa nedá meniť.

## 18.4 E-maily o zmenách v chránených oblastiach

Karta **E-maily o zmenách v chránených oblastiach** na stránke *Chránené oblasti* (nastavuje len strážca). Keď používateľ v skupine chránenej oblasti (nie strážca ani osoba len s PIN-om) **pridá, zmení alebo zmaže objekt**, ktorého typ oblasť chráni:

- zapíše sa do **Audit logu** udalosť *Zmena objektu v chránenej oblasti* (používateľ, oblasť, typ a názov objektu),
- **strážcovia a správca úseku**, ktorý pokrýva daný typ objektu, dostanú **e-mail** (vynímajúc samotného autora zmeny): zmenené polia z → na.

| Voľba | Predvolené | Význam |
|---|---|---|
| Posielať administrátorom, čo používatelia zmenili v chránených oblastiach | zapnuté | vypnuté: e-maily neidú, do Audit logu sa zapisuje ďalej |

| | | |
|---|---|---|
| Posielať používateľovi e-mail o zmenách jeho prístupu | zapnuté | používateľ, ktorému sa udelí prístup do chránenej oblasti (*Access granted*) alebo ho odoberú zo skupiny (*Váš prístup do NetBoxu sa zmenil*), dostane e-mail, tak ako osoby len s PIN-om |
| Súhrn každých | 60 minút | 5, 15, 30, 60, 120, 240 minút alebo raz za deň: jeden e-mail so všetkými zmenami |
| Pri každej zmene | – | jeden e-mail na zmenu, odošle sa po uložení cez `netbox-rq`. Nikdy nie oboje naraz |

E-mail príde len tomu, kto má adresu v **overenej doméne** (kapitola E-maily). Súhrny spracúva systémová úloha každých 5 minút, preto treba bežiaci `netbox-rq`. Pri prvom spustení sa nič z minulosti neposiela. Osoby len s PIN-om majú vlastné e-maily (kapitola Osoby len s PIN-om). Zmeny nájdeš aj v Changelogu NetBoxu.

### 18.5 Núdza na serveri

```
python manage.py userpin_keeper                # zobrazí strážcov
python manage.py userpin_keeper --add <meno>   # vymenuje strážcu
python manage.py userpin_default_deny --on     # zapne ochranu (potrebuje strážcu)
python manage.py userpin_default_deny --off    # vypne ochranu
```

Každá zmena cez príkaz sa zapíše do auditu a **e-mailom sa dozvedia všetci strážcovia a superuseri** (nič sa nedeje potichu).

## 19. Výnimky

**Kto:** len strážca nastavuje, mení a odoberá. Výnimku môže mať bežný používateľ (nie strážca, nie osoba len s PIN-om).
**Kedy:** keď má jeden používateľ pracovať podľa oprávnení NetBoxu bez zákazu (napr. správca siete, ktorého ochrana obmedzuje).
**Závisí od:** zapnutá ochrana (pri vypnutej sa nič neberie).

Používateľ s výnimkou nie je viazaný ochranou: pracuje s oprávneniami, ktoré mu dáva NetBox. Jeho skupiny, prístupy a roly ostávajú a platia znova, keď sa výnimka odoberie alebo skončí. Superuser s výnimkou vidí všetko bez PINu. Karta **Výnimky** je na stránke *Chránené oblasti*.

### 19.1 Zapnutá a vypnutá výnimka (prepínač)

Pri každom používateľovi je **posuvný prepínač**. Používateľ ostáva v zozname so všetkými nastaveniami (čo smie používať, dôvod, koniec) a výnimku zapínaš a vypínaš jedným klikom, **bez odoberania**:

| Prepínač | Čo platí |
|---|---|
| **Výnimka zapnutá** | používateľ ide **podľa NetBoxu** a z účtových stránok a API smie len to, čo mu strážca zaškrtol (*Smie používať*) |
| **Výnimka vypnutá** | používateľ ide **podľa PIN-u**: ochrana naňho platí ako na bežného používateľa (skupiny, zákazy). Zoznam povolení sa vtedy nepoužíva, ale ostáva uložený a platí znova po zapnutí |

- Prepínať môže len strážca. Zmena sa prejaví hneď (najneskôr do 5 sekúnd), zapíše sa do auditu a ostatným strážcom príde e-mail *Protection exception switched on / off*.
- V zozname má každý riadok štítok *Výnimka zapnutá* (zelený), *Výnimka vypnutá* (žltý) alebo *Ukončená* (šedý) a pod prepínačom text, kto ho práve riadi (*Riadi ho NetBox, len to, čo je povolené* / *Riadi ho PIN*).

## 19.2 Koniec výnimky (dátum a čas)

- Pri každom používateľovi je pole **Do** s dátumom a časom a tlačidlom *Uložiť*: koniec môžeš kedykoľvek zmeniť. **Prázdne pole = bez konca.** Nový koniec musí byť v budúcnosti.
- **Keď koniec uplynie**, používateľa hneď (do 5 sekúnd) znova riadi PIN a systémová úloha (každých 5 minút) prepne prepínač na *Výnimka vypnutá* a zapíše to do auditu; ostatní strážcovia dostanú e-mail *Protection exception ended*. Riadok zostane v zozname so štítkom *Ukončená*.
- **Ukončenú výnimku znova zapneš** tak, že najprv nastavíš nový koniec (alebo ho vymažeš) a potom prepínač zapneš. Zapnutie s uplynulým koncom stránka odmietne (*Výnimka skončila: pred zapnutím nastav nový koniec (alebo žiadny)*).

## 19.3 Hľadanie a zoznam pre veľa používateľov

- Nad zoznamom je **Hľadanie** (meno, účet alebo dôvod) a filter **Stav**: Všetky / Výnimka zapnutá / Výnimka vypnutá / Ukončená. Tlačidlo *Zrušiť filter* ho vyčistí. Po zmene prepínača alebo konca sa vyhľadávanie zachová.
- Zoznam je **stránkovaný po 25**. Hore je súhrn (*Výnimiek: N, zapnutých X, vypnutých Y*).
- Pri pridávaní je nad výberom používateľa **pole na hľadanie**: píšeš a zoznam sa zúži; keď ostane jeden, vyberie sa sám.

## 19.4 Pridanie výnimky

Formulár: *Používateľ* (neponúkajú sa strážcovia ani tí, čo už výnimku majú), *Do (voliteľné)* (koniec; musí byť v budúcnosti), *Prečo (voliteľné)* (do 200 znakov) a tlačidlo *Smie používať* s položkami (pozri nižšie), potom *Nastaviť výnimku*. Nová výnimka je **zapnutá**. Ostatným strážcom príde e-mail *Protection exception: meno* a zapíše sa do auditu. Ak je používateľ v skupinách, stránka upozorní, že pre čas výnimky neplatia. Opätovné pridanie toho istého používateľa sa odmietne (zmeny sa robia v zozname).

## 19.5 Čo smie používateľ s výnimkou

Výnimka sa týka ochrany, nie účtových stránok a API. Tie smie používateľ používať len ako strážca povolil:

| Položka | Predvolené | Čo sa pri zákaze stane |
|---|---|---|
| Zmeniť heslo | povolené | karta Heslo a odkaz v menu zmiznú, adresa vráti 403 |
| Profil | zakázané | karta a adresa `/user/profile/` |
| Predvoľby | zakázané | `/user/preferences/` |
| Záložky | zakázané | `/user/bookmarks/` |
| Notifikácie | zakázané | `/user/notifications/` a skrytý zvonček |
| Odbery | zakázané | `/user/subscriptions/` |

| | | |
|---|---|---|
| API tokeny (vytvárať a spravovať vlastné) | zakázané | `/user/api-tokens/`, `/users/tokens/`, `/api/users/tokens/`; zmizne aj položka *Admin → API Tokens*. Platí rovnako pre prehliadač aj pre token a nezávisí od voľby *API*. Každý (aj superuser) vidí a mení **len vlastné** kľúče; cudzie spravuje len strážca |
| API (REST, GraphQL) | zakázané | zakázané je **všeobecné REST a GraphQL API** pre token aj pre reláciu s cookies prehliadača (aj `/api/status/`). Token takého používateľa je odmietnutý. Jediná výnimka: výber hodnôt v rozbaľovacom zozname formulára (GET s `?brief`), bez ktorého by formuláre nefungovali |

- Pri každom používateľovi je pod menom šípka ▾ **Smie používať**, ktorá rozbalí zaškrtávacie polia s tlačidlom *Uložiť*, a malé štítky: zelený ✓ povolené, červený ✗ zakázané.
- Čo nie je povolené, zmizne z menu a kariet a priama adresa vráti 403 (*Not allowed for this account*, s menami strážcov).
- NetBox nemá v menu používateľa odkaz na heslo (je len ako karta v Profile). Kým je heslo povolené, plugin ho do menu doplní.
- **Cesty účtu, ktoré nikto nezaradil, sú zakázané** (default deny): v osobnom účte (`/user/…`) a v aplikácii používateľov (`/users/…`, `/api/users/…`) platí, že čo nie je v zozname, je zatvorené. Správa používateľov, skupín a oprávnení ostáva pod oprávneniami NetBoxu. Ostatné dátové adresy NetBoxu (zariadenia, IPAM …) tým nie sú dotknuté.
- **Strážca môže vždy všetko.** Pri vypnutej ochrane sa nič neberie. Superuser, ktorý nie je strážca, kým strážca nie je, tiež nie je obmedzený. Pri *vypnutej* výnimke sa zoznam povolení nepoužíva (používateľa riadi PIN).

**Prečo to je dôležité.** NetBox dáva každému prihlásenému právo na vlastné API tokeny (`DEFAULT_PERMISSIONS`), takže používateľ bez akýchkoľvek práv vidí v menu *Admin → API Tokens*. Token nesie len oprávnenia svojho majiteľa, no požiadavky s tokenom plugin PIN-om neposudzuje: používateľ s právami by cez token čítal aj mimo svojich oblastí. Zoznam povolení to rieši bez zásahu do konfigurácie NetBoxu.

## 19.6 API tokeny a PIN: vedomá bezpečnostná hranica

**Rozhodnutie vlastníka projektu (variant A).** Požiadavka, ktorú NetBox overil **platným API tokenom**, sa PIN ochranou chránených oblastí a poľami **neposudzuje**: riadi sa výhradne oprávneniami NetBoxu (RBAC) majiteľa tokenu. Je to zámer, aby fungovali integrácie a skripty (monitoring, synchronizácie, zálohy), ktoré nemajú PIN ani prehliadač.

- Kto má token, vidí a pri zodpovedajúcich právach aj mení a maže všetko, čo mu povoľuje NetBox, **aj mimo svojich oblastí a skrytých polí** (aj cez GraphQL). V prehliadači by ho PIN zastavil.
- Preto dávaj tokeny len **účtom s minimálnymi oprávneniami NetBoxu** (oprávnenia s obmedzením na potrebné objekty, len čítanie tam, kde stačí) a nepoužívaj superuser účty na integrácie.
- Token musí byť **skutočne platný**. Falošná hlavička `Authorization` pri prihlásenej relácii ochranu nevypne: pri relácii rozhoduje relácia a PIN sa uplatní.
- Pre účty s výnimkou rozhoduje aj zaškrtnutie *API* (token bez neho je odmietnutý) a pre správu kľúčov *API tokeny*.
- Používateľ môže mať vlastný kľúč len ak to nastavenia dovolia (*Používatelia smú vytvoriť vlastný API kľúč*) a vidí len svoje kľúče.

Zmena tohto pravidla (aby sa token riadil oblasťami ako človek) je možná ako samostatná verzia, ale vyžaduje, aby každý integračný účet dostal skupinu v oblasti alebo výnimku.

### 19.7 Keď PIN nevie prečítať stav ochrany

Ak plugin nevie prečítať databázu (oblasti, strážcov, výnimky), **nič nepovolí**: studený proces alebo stav starší ako 30 sekúnd odpovie **HTTP 503** (*The protection of the data cannot be checked now*) a po zotavení databázy sa ochrana načíta znova. Posledný známy stav sa drží najviac 30 s a databáza sa pýta každú sekundu. Pri úplnom výpadku databázy skončí NetBox chybou ešte skôr (500), bez dát. Zmena ochrany (výnimka, strážca, oblasť) sa v ostatných procesoch NetBoxu prejaví do pol sekundy (zdieľaná cache), koniec výnimky je presný aj bez `netbox-rq`.

# 20. Správcovia úsekov

**Kto vymenúva a odoberá:** strážca (kým nie je, CORE / master). Správca úseku správcov nevymenúva ani neodoberá.

**Kedy:** keď má o časti oblasti rozhodovať niekto iný než strážca: skupiny, polia, členovia, žiadosti.

**Závisí od:** správca musí mať PIN a 2FA, byť bežný účet NetBoxu (nie superuser, nie strážca, nie osoba len s PIN-om).

- **Úsek** = typy objektov oblasti (aplikácia alebo typ); **nič nezaškrtnuté = celá oblasť**. Pri správcovi je tlačidlo *Uložiť úsek*; nového určuješ tlačidlom *Určiť správcov úsekov* (formulár *Úsek* + výber používateľov).
- Správca má **plnú moc nad svojím úsekom**: skupiny, polia, členov a žiadosti. Strážcovia sú nad ním. Rolu oddelenia nepotrebuje.
- Žiadosti o jeho typy idú **jemu aj strážcom**; každé rozhodnutie sa posiela e-mailom žiadateľovi, strážcom a správcovi.
- Prístupy len cez PIN vytvorené strážcom patria strážcom; správca vidí len tie, ktoré sú **pod ním**, a zakladá ich len do skupín svojho úseku (strážcovia dostanú e-mail). Strážca môže prístup presunúť pod správcu.
- Správca celej oblasti si ponecháva práva nad oblasťou (cieľ, profily); vytváranie oblasti, pridávanie a odoberanie cieľov a správcov patrí strážcom. **Posledného správcu oblasti** môže odobrať len strážca (CORE / master, kým strážca nie je, ho odobrať nemôže, okrem správcu, ktorý sa medzitým stal superuserom alebo strážcom).
- Vymenovaním správcu sa mu automaticky **povolí používanie PINu** (ak ho správca PINov výslovne nezakázal: vtedy vymenovanie zlyhá).
- Stránka pri vymenúvaní ukáže, čo správcovi chýba (*Má PIN*, *Má 2FA*, *Nie je superuser ani strážca*, *Je účet NetBoxu*).
- Núdza na serveri: `python manage.py userpin_area_owners <kľúč-oblasti> --set meno1 meno2` (zapíše sa do auditu; odmietne ľudí, ktorí by správcami byť nemohli, ak nedáš `--force`).

# 21. Ľudia len s PIN-om (PIN-only)

**Kto ich vytvára a spravuje:** strážca ochrany (všetky) a správca úseku (len tie, ktoré sú pod ním a do skupín jeho úseku). Menu *Ľudia len s PIN-om* vidí strážca a správca.

**Kedy:** pre ľudí, ktorí nemajú účet v NetBoxe a majú vidieť alebo meniť len časť (napr. technik na tenantoch).

**Závisí od:** nastavená pošta (osobný odkaz príde e-mailom; bez nej ho vidíš na obrazovke), skupina v chránenej oblasti, zapnutá ochrana (pri vypnutej môže osoba len meniť PIN), bežiaci `netbox-rq` (zhrnutia zmien).

Za osobou stojí technický používateľ `PinUser0001`, `PinUser0002` … (číslo sa nikdy nepoužije znova ani nezmení; *alias* a popis sú voľné texty a nič sa v NetBoxe nepremenúva). Technický účet **nemá použiteľné heslo**: prihlásiť sa dá len cez stránku PIN. V zozname používateľov, v rozbaľovacích zoznamoch ani v API ho nikto nevidí. Záznam zmien NetBoxu ukazuje technického používateľa.

## 21.1 Nový prístup (formulár)

| Pole | Povinné | Význam |
|---|---|---|
| Meno | áno | meno osoby (do 150 znakov); používa sa len pre správcu, osoba sa volá osobným číslom |
| E-mail | áno | platná adresa. **Nesmie** patriť inému prístupu ani účtu NetBoxu: ak ju už má účet, stránka vysvetlí, že osoba sa má prihlasovať vlastným účtom (pridaj ho do skupiny ako bežného používateľa) |
| Osobné číslo | **áno** | osobné číslo osoby v organizácii (do 40 znakov). **Jedinečné** a po uložení sa **nedá zmeniť**; pred uložením sa systém opýta „Skontrolujte osobné číslo ešte raz“. Osoba sa ním a PIN-om prihlasuje a podľa neho sa všade volá: `UserPIN : 12345` |
| Skupina | strážca nie; správca áno | skupina z chránenej oblasti. Bez skupiny (len strážca) môže osoba iba meniť svoj PIN. Správca vyberá len zo skupín svojho úseku |
| Prístup končí (voliteľné) | nie | dátum a čas v budúcnosti; potom sa osoba neprihlási. Prázdne = bez konca |
| Nečinnosť (minúty) | – | predvolene 30 (5 až 240) |
| Relácia (hodiny) | – | predvolene 8 (1 až 24) |
| Povolené IP adresy (voliteľné) | nie | adresy alebo siete (napr. `10.0.0.0/24`), oddelené čiarkou, bodkočiarkou alebo riadkom; neplatný záznam sa odmietne |
| Alias, Popis (voliteľné) | nie | alias do 100, popis do 150 znakov |
| Jazyk PIN stránok; Jazyk NetBoxu | nie | predvolený / Slovenčina / English; jazyk PIN stránok a e-mailov, a jazyk rozhrania NetBoxu pre túto osobu |
| Pracovný čas | nie | všeobecné pravidlá / vlastné pravidlá / bez obmedzenia (pozri kapitolu Pracovný čas) |

| | | |
|---|---|---|
| Posielať osobe e-maily o zmenách | – | pozri nižšie |

## 21.2 Prvé prihlásenie osoby

1. Osoba dostane e-mailom **osobný odkaz** (platí **7 dní**; *Poslať odkaz znova* vydá nový a starý prestane platiť). Odkaz otvorí stránku *Ahoj UserPIN : OC* (osoba sa volá osobným číslom).
2. Zvolí si **vlastný PIN**: podľa pravidiel PINu (predvolene **8 až 64 znakov**, nie len číslice, aspoň 4 rôzne znaky; správca môže vyžadovať aj písmeno a číslicu, pozri nižšie). Pri osobách s osobným číslom **nemusí byť PIN jedinečný**. Nikto ho neprečíta, ani správca.
3. Tlačidlo *Nastaviť PIN a prihlásiť sa*. Ak pozvánka vypršala: *Požiadajte správcu o novú.*

Ak nie je nastavená pošta, odkaz sa správcovi **ukáže na obrazovke** (iba raz, *Odovzdajte tento osobný odkaz sami*).

## 21.3 Osobné číslo a pravidlá prihlásenia

- **Osobné číslo (OC)** zadáva správca pri vytvorení osoby (povinné) alebo neskôr v riadku osoby (blok *Alias a popis*, pole *Osobné číslo (prihlásenie)*). Je jedinečné a po uložení **sa nedá zmeniť**; osoba o ňom dostane e-mail.
- Osoba sa volá `UserPIN : OC` všade: v zozname osôb (druhý riadok *ID: 1* je číslo technického účtu), v Audit logu (používateľ aj vykonal), v e-mailoch, v hornom menu, na úvodnej stránke osoby a na stránkach zablokovania. Meno sa v zozname nezobrazuje.
- Karta **Pravidlá prihlásenia a PIN-u (pre všetkých)** (stránka *Ľudia len s PIN-om*, len strážca): *Osobné číslo je povinné*, *Najkratší PIN* (6 až 64), *PIN musí obsahovať písmeno*, *PIN musí obsahovať číslicu*.
- **Osobné číslo povinné** sa nedá zapnúť, kým má niektorý prístup bez čísla (stránka vypíše, komu chýba). Po zapnutí dostane každý e-mail *Prihlasovanie do NetBoxu sa mení* a samotný PIN už nestačí; prihlasovacia stránka má dve polia (*Osobné číslo* a *PIN*) a veľký červený oznam.
- **Prísnejšie pravidlo PINu** (dlhší PIN, povinné písmeno alebo číslica): každý dostane e-mail a pri najbližšom prihlásení pôvodnými údajmi si musí zvoliť nový PIN; stránka zmeny ukáže pravidlo a príklad (`Kava2026Moja`).
- Kým číslo povinné nie je, osoba bez čísla sa prihlási samotným PIN-om (PINy takých osôb zostávajú jedinečné, *Zvoľte iný PIN*). Osoba s číslom sa môže prihlásiť číslom a PIN-om; zlé číslo alebo PIN dáva rovnakú hlášku *Osobné číslo alebo PIN nie je správny*.

## 21.4 Čo osoba vidí: len svoje oblasti

Osoba len s PIN-om vždy žije v režime B (nech je v nastaveniach akýkoľvek): vidí **len oblasti, kde je v skupine**. Ak nie je v žiadnej, nevidí nič. Položky mimo jej skupín (napr. Devices) z menu zmiznú a nemajú ani „dvere“.

## 21.5 Bežné prihlasovanie: jedna spoločná adresa

- Všetci používajú **jednu spoločnú stránku** (predvolene `/pin/`) a zadajú **osobné číslo a PIN** (kým číslo nie je povinné, osoby bez čísla zadajú len PIN: PIN povie, kto to je). Adresu volí strážca na stránke (*Adresa prihlásenia PINom*: časť A a voliteľne B, napr. `/tenanti/` alebo `/aqer/x2/`; nerozlišuje veľkosť písmen). Osoba si ju uloží ako záložku; **nemení sa**, kým ju strážca nezmení (po zmene si ju musia uložiť znova).
- Osobný odkaz z e-mailu funguje tiež (osoba je na ňom známa).

- Ak PIN zabudla: *Zabudol som PIN – pošlite mi odkaz na nový* (adresa, odkaz platí **1 hodinu, raz**, najviac jeden za minútu; nefunguje pre zakázaný alebo skončený prístup).

## 21.6 Čo osoba vidí a nemôže

- Úvodná stránka: *Ste prihlásený ako UserPIN : OC*, platnosť PINu (dni a hodiny), **pracovný čas** (*Váš pracovný čas*), po konci času *Je po čase: ešte jedno uloženie, potom len čítanie*, nečinnosť po ktorej relácia končí a zoznam prístupov (*skupina X, smiete..., platí do ...*) s tlačidlom *Pokračovať*. Bez skupiny: *Zatiaľ vám nebol daný žiadny prístup. Môžete len zmeniť PIN.* Pri vypnutej ochrane: *Funkciu zatiaľ vypol správca. Môžete len zmeniť PIN.*
- Menu používateľa: *Môj prístup*, *Zmeniť môj PIN*, *Odhlásiť*. Nemá heslo, 2FA, API ani token; nikdy nie je strážca, správca ani výnimka. Účtové stránky a stránky pluginu sú jej zatvorené. Žiadosti o prístup robiť nemôže.
- Rozbaľovacie zoznamy vo formulároch jej fungujú (stručné zoznamy API); zvyšok API je zatvorený. Ukladá si vlastné stĺpce tabuliek.
- **Zmena PINu** (*Zmeniť môj PIN*): aktuálny PIN, nový PIN, nový PIN znova. Po vypršaní alebo vynútení sa pýta pred pokračovaním.

## 21.7 Zlé PINy

Pravidlá sú *Zlé PINy na krok* (predvolene 5; 1 až 50) a *Čakanie po každom kroku (sekundy)* (predvolene `10,20,30`; 1 až 10 čakaní po 1 až 3600 s). Nastavujú sa pre všetkých (*Pravidlá pre zlé PINy (predvolené)*) a môžu mať aj vlastné pre jednu osobu; prázdne = predvolené.

| Kde | Čo sa stane |
|---|---|
| **Osobný odkaz** | osoba je známa: po každých 5 zlých PINoch čakanie (10, 20, 30 s); po poslednom kroku je prístup **zablokovaný** (osoba aj strážcovia dostanú e-mail). Odblokuje len správca (*Odblokovať*), alebo osoba nastaví nový PIN cez e-mail s odkazom |
| **Spoločná stránka s osobným číslom** | správne číslo a zlý PIN sa pripíše osobe: rovnaké kroky a **zablokovanie** ako pri osobnom odkaze. Neznáme číslo je ako zlý PIN bez osoby (čaká počítač) a hláška je rovnaká *Osobné číslo alebo PIN nie je správny*, takže sa nedá zistiť, ktoré čísla existujú |
| **Spoločná stránka bez čísla** (kým číslo nie je povinné) | zlý PIN sa nedá pripísať osobe: čaká **počítač** (jeho adresa) podľa rovnakých krokov, posledné čakanie sa opakuje, **nikto sa neblokuje**, a strážcovia dostanú e-mail po každom plnom kole (15 zlých PINov) *Wrong PINs from ...* |

Zablokovaná osoba vidí *Prihlásenie nie je možné* a tlačidlo *Požiadať správcu o odblokovanie* (najviac raz za hodinu; e-mail správcovi, ktorý prístup zakázal, alebo strážcom).

## 21.8 Akcie pri osobe

| Akcia | Čo robí |
|---|---|
| Odblokovať | starý PIN znova funguje, počítanie od nuly |
| Poslať e-mail na reset | odkaz na nový PIN (platí 1 hodinu, raz); nový PIN aj odblokuje |
| Vynútiť zmenu PINu | pri najbližšom prihlásení sa pýta nový PIN |
| Poslať odkaz znova | nový osobný odkaz (starý prestane platiť) |

| | |
|---|---|
| Resetovať PIN | PIN sa vymaže a pošle sa **nový osobný odkaz**, cez ktorý si osoba zvolí nový PIN (bez pošty sa odkaz ukáže na obrazovke) |
| Zakázať / Povoliť | zakázanie ukončí všetky relácie a zablokuje prihlásenie (osoba vidí „zakázal X od …“); povolenie prístup vráti |
| Zmazať | odstráni prístup aj technického používateľa |

Pri každej osobe je rozbaliteľná **Aktivita a pravidlá**: *Prihlásenia a udalosti PINu*, *Zmeny v NetBoxe*, formuláre *Alias a popis* (a *Jazyk PIN stránok a e-mailov*, *Jazyk rozhrania NetBoxu*), *Správca* (strážcovia; pod správcom úseku ho vedie on, strážca vždy; presun pod správcu), *E-maily*, *Pracovný čas*, *Prístup platí do* (prázdne = bez konca; za koniec sa osoba neprihlási; 30 dní a 1 deň vopred jej príde e-mail) a *Pravidlá pre zlé PINy*.

## 21.9 Relácia osoby

Relácia skončí po *Nečinnosti* minút (predvolene 30; 5 až 240) alebo najviac po *Relácii* hodinách (predvolene 8; 1 až 24), po konci platnosti prístupu, po zakázaní, alebo keď príde požiadavka z adresy mimo zoznamu povolených IP. Nastavuje sa pri každom prístupe zvlášť. Po odhlásení sa osoba vráti na spoločnú stránku PIN.

## 21.10 E-maily oboma smermi

| Smer | Čo | Nastavenie |
|---|---|---|
| **Osobe** | každá akcia správcu: skupiny, zakázanie / povolenie, reset PINu, odblokovanie, platnosť, jazyky, pravidlá, pracovný čas, správca, alias/popis, zmazanie. Mail ide na jej vlastnú adresu (bez ohľadu na povolené domény) v jej jazyku | *Posielať osobe* (celá stránka) a *Posielať osobe (každá zmena prístupu)* pri prístupe. Ak je vypnuté na stránke, **vyhráva to** |
| **Audit log** | každá zmena objektu osobou (aj osobou len s PIN-om) je v Audit logu (*Zmena objektu v chránenej oblasti*) s **rozbaliteľným detailom**: prvý riadok je ako predmet e-mailu (*OC : vytvorený Tenant – názov*, *zmena parametrov*, *zmazaný*) a pod šípkou je riadok na každé pole: pri novom alebo zmazanom objekte každé vyplnené pole, pri zmene len zmenené (z → na); súvisiace objekty sú menom, nie číslom; hodnoty polí s názvom obsahujúcim pass, secret, token, key, pin alebo hash sú ako *** | vždy |
| **Správcom** | čo osoba v NetBoxe pridala, zmenila alebo zmazala (so zmenenými poľami), správcovi, ktorý prístup vytvoril, a strážcom | *Posielať správcom* (celá stránka) a pri prístupe |

Správcovia dostanú zmeny buď ako **zhrnutie** každých N minút (*Zhrnutie každých*: 5, 15, 30, 60, 120, 240 minút alebo raz za deň; predvolene 60), alebo **pri každej zmene** (jeden e-mail na zmenu): **nikdy oboje naraz**. Predmet pri každej zmene: *OC : vytvorený Tenant – názov* (alebo *zmena parametrov*, *zmazaný*); v súhrne *OC : zmeny (3)*. Telo: *USER PIN : OC* a bloky ** vytvorený Tenant názov (čas)* s riadkom ** Pole: hodnota* pre každé vyplnené pole (prázdne sa vynechajú), pri zmene ** Pole: z „a“ na „b“* len pre zmenené polia; súvisiace objekty menom. E-mail sa odošle až po uložení cez frontu `netbox-rq`, takže ukladanie ostáva rýchle; zhrnutia spracúva systémová úloha každých 5 minút. Strážca zmeny nastavuje v karte *E-maily (pre všetkých)*.

> Správca úseku pri práci s prístupom oznamuje strážcom e-mailom (nič sa nedeje potichu). Prístup vytvorený strážcom patrí strážcom, kým ho nepresunú pod správcu.

# 22. Pracovný čas

**Kto nastavuje:** strážca (všeobecné pravidlá aj pravidlá jednotlivých prístupov).
**Kedy:** keď majú osoby len s PIN-om pracovať len v pracovnom čase.
**Závisí od:** zapnuté *Obmedziť pracovný čas prístupov len cez PIN* (predvolene vypnuté), knižnica `holidays` pre sviatky, časová zóna servera (`TIME_ZONE` v NetBoxe).

## 22.1 Pravidlá

Všeobecné pravidlá sú na stránke *Ľudia len s PIN-om* (karta **Pracovný čas (pre všetkých)**): *Obmedziť pracovný čas*, *Krajina (sviatky)* (predvolene SK), *Dni* (predvolene Po až Pi), *Od* (06:00) a *Do* (16:00). Pri každom prístupe sa dá zvoliť:

| Voľba | Význam |
|---|---|
| *všeobecné pravidlá* | platí pravidlo stránky (ak je obmedzenie zapnuté; inak bez obmedzenia) |
| *vlastné pravidlá* | vlastná krajina, dni a hodiny (napr. technik z Maďarska s maďarskými sviatkami) |
| *bez obmedzenia* | osoba nemá žiadny limit |

- **Pri každej osobe je napísané**, aký čas má: *Pracovný čas: nastavený individuálne (…)*, *Pracovný čas: vypnutý (bez obmedzenia)* alebo *Pracovný čas: platí všeobecný čas (…)* (ak je všeobecný čas vypnutý, stojí tam, že je vypnutý a limit nie je).
- **Zmenené dni alebo hodiny pri voľbe *všeobecné pravidlá* sa neuložia a plugin to povie**: *Pre tento prístup platí všeobecný pracovný čas, preto sa zmenené dni alebo hodiny nedajú uložiť. Vyber „vlastné pravidlá“ … alebo „bez obmedzenia“.* Vlastný čas sa uloží len pri voľbe *vlastné pravidlá*.
- **Návrat na všeobecné pravidlá** (z vlastných alebo z vypnutých) zahodí vlastné hodnoty osoby: osoba si vezme čas zo všeobecných pravidiel (aj pri neskoršej zmene všeobecného času).

Krajiny: SK, CZ, HU, AT, PL, DE, UA, HR, SI, RO, BG, RS, GB, IE, FR, ES, IT, NL, BE, CH, SE, NO, DK, FI, PT, GR, LT, LV, EE, US, CA. Štátne sviatky dodáva knižnica `holidays` (funguje offline, vyžaduje `pip install holidays`; bez nej stránka hlási *The library of public holidays is not installed* a kontrolujú sa len dni a hodiny). Sviatky sa riadia zákonom, ktorý knižnica implementuje: napr. na Slovensku v roku 2026 sú voľné 1. 1., 6. 1., Veľký piatok, Veľkonočný pondelok, 1. 5., 5. 7., 29. 8., 1. 11. a 24., 25., 26. 12., kým 8. 5., 1. 9., 15. 9. a 17. 11. sú pracovné dni. Vlastné voľné dni ani dovolenky plugin nemá.

## 22.2 Čo sa deje mimo času

- Osoba sa **môže prihlásiť a pozerať**, ale **nemôže nič ukladať ani upravovať**: žiadne ukladanie, pridávanie, úprava, mazanie ani zápis cez API. Zakázané požiadavky sa presmerujú s hláškou (*Mimo vášho pracovného času (…) môžete len čítať*), API odpovie 403.
- Pracovný čas je **vždy viditeľný**: na úvodnej stránke a v hornej lište, v jazyku osoby. V sviatok sa pred ním napíše *Dnes je štátny sviatok (názov)*.
- Keď čas skončí **počas práce**: **30 minút a jedno uloženie**, potom už len čítanie.
- Stav dňa: v čase / po skončení (30 minút) / pred začiatkom / po skončení / voľný deň alebo sviatok.

# 23. Príkazy na serveri

**Kto:** správca servera (root).
**Kedy:** pri inštalácii, výmene kľúča, v núdzi (strata telefónu, zamknutá ochrana, nefunkční správcovia).
**Závisí od:** aktivované virtuálne prostredie NetBoxu. Núdzové príkazy sa zapisujú do auditu.

Spúšťajú sa takto (nahraď `<príkaz>`):

```
sudo bash -c 'source /opt/netbox/venv/bin/activate && cd /opt/netbox/netbox && python manage.py <pr
íkaz>'
```

| Príkaz | Čo robí |
|---|---|
| `userpin_generate_key [--key-id k1]` | vygeneruje náhodný šifrovací kľúč (vypíše ho, nič neukladá) |
| `userpin_rotate_key` | prešifruje všetko pod aktívnym kľúčom (PIN hashe, 2FA, záložné kódy, SMTP heslo); v jednej transakcii, pri chybe sa nič nezmení |
| `userpin_check` | overí, že sa všetko uložené pod kľúčmi dá dešifrovať, a ukáže, koľko hodnôt a osôb len s PIN-om čaká na starý kľúč |
| `userpin_keeper [--add meno]` | zobrazí strážcov alebo vymenuje jedného (audit, e-mail všetkým strážcom a superuserom) |
| `userpin_default_deny [--on \| --off]` | zobrazí alebo prepne globálnu ochranu (audit, e-mail; zapnutie potrebuje strážcu) |
| `userpin_area_owners <oblasť> [--set mená…] [--force]` | zobrazí alebo nahradí správcov oblasti (audit); bez `--force` odmietne ľudí, ktorí by správcami byť nemohli |
| `userpin_reset_2fa <používateľ>` | núdzovo odstráni 2FA (napr. master bez telefónu a záložných kódov; audit) |
| `userpin_access_test <používateľ> [--url …] [--all] [--writes]` | ukáže, čo používateľ dostane zo stránok, REST API (prehliadač) a zoznamov (test ochrany). `--url` pridá ďalšiu adresu, `--all` skúsi každú stránku NetBoxu, `--writes` aj pridanie, zmenu a zmazanie |

# 24. Kontrola: pin_check.sh

**Kto:** správca; skript sa dá spustiť aj z iného počítača než server.
**Kedy:** po inštalácii, po aktualizácii pluginu aj NetBoxu.
**Závisí od:** `curl`; pri voľbe `--server` root na serveri NetBoxu.

Skript `tools/pin_check.sh` (v repozitári) kontroluje všetko, čo sa dá zvonku, a so `--server` aj na serveri. Nikdy neukladá ani nevypisuje PIN či token (PIN sa pýta potichu). Výsledok je počet **OK** / **FAIL** / **WARN**.

```
bash pin_check.sh http://172.30.1.25                                  # len anonymné kontroly
bash pin_check.sh http://172.30.1.25 --pin /pin/                      # + prihlási osobu len s PIN-
om
NB_TOKEN=xxxx bash pin_check.sh http://172.30.1.25                    # + kontroly s API tokenom
sudo bash pin_check.sh http://127.0.0.1 --pin /pin/ --server          # + migrácie, služby, kľúče,
strážcovia
```

Voľby: `--pin <cesta>` (adresa stránky PIN-only, predvolene `/pin/`), `--wrong` (skúsi **jeden** zlý PIN; počíta sa ako chybný pokus), `--write` (skúsi pridať tenanta ako osoba len s PIN-om a zmaže ho), `--server` (vyžaduje root). Premenné: `NB_TOKEN`, `NB_VENV`, `NB_DIR`, `LIST`.

Kontroly majú oddiely: 0 dostupnosť; 1 nikto neprihlásený; 2 s API tokenom; 3 osoba len s PIN-om; 4 čo osoba nikdy nesmie dosiahnuť; 5 stránka, ktorú smie otvoriť; 6 pridanie ako osoba len s PIN-om; 7 odhlásenie; 8 na serveri (migrácie, služby, kľúče, strážcovia). Známe neškodné upozornenia: `/static/docs/` servíruje nginx (zatvorí sa `location /static/docs/ { return 404; }`) a `LOGIN_REQUIRED` nie je `True` (nastav v `configuration.py`; NetBox 5.0 ho zruší).

# 25. Bezpečnostný model

```
PIN ──Argon2id + soľ──► hash ──AES-256-GCM (kľúč z konfigurácie, viazaný na ID používateľa)──► data
báza
```

- Samotný výpis databázy neobsahuje nič použiteľné, ani čo by sa dalo lámať offline.
- Šifrovaný text je viazaný na používateľa: hash skopírovaný do riadku iného používateľa sa nedešifruje.
- Zlé pokusy sa počítajú pod zámkom riadku, takže paralelné hádanie zablokovanie neobíde.
- Zmena alebo reset PINu zneplatní všetky odomknutia. Tajomstvá TOTP sú šifrované rovnako; kód TOTP sa prijme len raz.
- Záložné kódy (100 bitov) a e-mailové kódy sa ukladajú len ako odtlačky, jednorazové a krátko platné.
- Obnova nikdy neobíde 2FA. PIN je len autentifikačný faktor („som to naozaj ja pri tomto počítači“), nepoužíva sa ako kľúč na šifrovanie iných dát.
- **Požiadavky s platným API tokenom plugin PIN-om neposudzuje** (token nesie oprávnenia NetBoxu; vedomé rozhodnutie vlastníka projektu, variant A): preto sú vlastné tokeny predvolene zakázané a pri výnimkách sa povoľujú po jednom a tokeny dávaj len účtom s minimálnymi oprávneniami. Falošná hlavička `Authorization` pri prihlásenej relácii ochranu nevypne.
- Prístup na server riadi firewall; samostatný port alebo hostname pre prihlásenie osôb len s PIN-om plugin nevynucuje, ak treba, rieši sa v nginxe a firewalle.
- Kto má root alebo prístup do databázy na serveri, obíde akýkoľvek plugin: odpoveďou je audit.

# 26. Použitie z iného pluginu

**Kto:** vývojár pluginu pre NetBox.

**Kedy:** keď chce iný plugin chrániť citlivé stránky PINom.

**Závisí od:** `netbox-user-pin` ako závislosť pluginu; verzia API (`service.API_VERSION` = 2, `areas.API_VERSION` = 1; API len rastie).

```
from netbox_user_pin.mixins import PinRequiredMixin, StepUpRequiredMixin, pin_required, step_up_req
uired

class ProjectView(PinRequiredMixin, generic.ObjectView):
    pin_scope = 'projects'          # pri režime rozsahu „osobitné podľa rozsahu“

class ProjectDeleteView(StepUpRequiredMixin, generic.ObjectDeleteView):
    ...                             # citlivá akcia: čerstvé PIN + 2FA

@pin_required(scope='projects')
def download(request, pk): ...
```

Používateľ je presmerovaný na *nastaviť PIN*, *zmeniť PIN* (vypršal) alebo *zadať PIN* a potom späť. Požiadavky HTMX dostanú hlavičku `HX-Redirect`.

Servisné API `netbox_user_pin.service`: `has_pin(user)`, `is_unlocked(request, scope)`, `unlock(request, pin, scope)`, `verify_pin(user, pin)`, `lock(request)`, `has_step_up(request)`, `has_2fa(user)`, `is_allowed(user)`. Signály (`netbox_user_pin.signals`, `sender=UserPin`): `pin_set`, `pin_changed`, `pin_reset`, `pin_unlocked`, `pin_failed`, `pin_locked_out`, `pin_locked`.

### 26.1 Oblasť pluginu

```
from netbox_user_pin import areas

# v ready(): oblasť je aktívna, kým je zapnutý vlastný prepínač „PIN integrácia“ pluginu
areas.register('netbox_libreoxi', 'LibreOXI', targets=['netbox_libreoxi'],
               rights={'config': 'Zobraziť konfigurácie zariadení'},
               profiles=[('Len logy', ['view']), ('Konfigurácie', ['view', 'config'])],
               enabled=lambda: LibreOXISettings.objects.first().pin_integration)

# vo view, pre jemnejšie práva
if (response := areas.require(request, 'netbox_libreoxi', 'config')) is not None:
    return response            # stránka „bez prístupu — požiadaj o ňu“
areas.can(request.user, 'netbox_libreoxi', 'config')   # True / False
```

## 27. Riešenie problémov

| Hlásenie / príznak | Príčina a riešenie |
|---|---|
| `ModuleNotFoundError: No module named 'argon2'` | Pri inštalácii s `--no-deps` sa nenainštalovali závislosti: `pip install "argon2-cffi>=23.1" "cryptography>=42" "segno>=1.5" "holidays>=0.50"`. |
| `CommandError: No installed app with label 'netbox_user_pin'` | Plugin nie je v zozname `PLUGINS` v `configuration.py`. Pridaj `'netbox_user_pin'` a zopakuj `migrate`. |
| NetBox sa po zmene konfigurácie nespustí | Chyba kľúča pri štarte (pozri kapitolu Inštalácia), alebo chyba v `configuration.py` (čiarka, apostrof). Pozri `journalctl -u netbox -n 80`. |
| pip: *holidays requires python-dateutil<3 but you have 3.0.0* | Neškodné upozornenie: `holidays` s dateutil 3 funguje (over výpisom sviatkov). Neinštaluj `python-dateutil<3`, mohol by si pokaziť NetBox. |
| `userpin_check` hlási chybu | Zlý alebo chýbajúci kľúč. Nemeň `k1`, kým sa nepotvrdí, že plugin funguje. |
| Nechodia e-maily | Pozri kapitolu E-maily: keď nejdú. |

| | |
|---|---|
| Rola sa nedá pridať: „nemá e-mail v overenej doméne“ | Pozvaný nemá adresu v overenej doméne alebo nie je pošta. Over doménu na stránke Mail. |
| Používateľ bez práv vidí Admin → API Tokens | Štandard NetBoxu (`DEFAULT_PERMISSIONS`). Pri výnimke ho plugin skryje, ak nie je povolené „API tokeny“. |
| 403 na stránke účtu pri výnimke | Táto časť nie je povolená: strážca ju zaškrtne pri výnimke. |
| Skupina používateľovi nič nedá | Má výnimku: skupina sa neuplatňuje, kým výnimka trvá. |
| Osoba len s PIN-om môže len čítať | Je mimo pracovného času (alebo sviatok), alebo je ochrana vypnutá. |
| Osoba len s PIN-om nevidí nič | Nemá skupinu, alebo je ochrana vypnutá. |
| Zhrnutia zmien osôb nechodia | Nebeží `netbox-rq` alebo je vypnuté *Posielať správcom*. |
| Integrácia alebo skript s tokenom dostáva 403 | Účet má výnimku a nemá zaškrtnuté *API* (a pri správe kľúčov *API tokeny*). Strážca ich zaškrtne pri výnimke. |
| HTTP 503 *The protection of the data cannot be checked now* | Plugin nevie prečítať databázu (oblasti, strážcov, výnimky) a preto nič nepovolí. Skontroluj PostgreSQL; po zotavení sa ochrana načíta sama. |
| Rozbaľovací zoznam vo formulári je prázdny pri výnimke | Výber hodnôt (`?brief`) PIN neblokuje; ak je prázdny, účet nemá v NetBoxe právo vidieť daný objekt. |
| Upgrade vrátil plugin na staršiu verziu | V `local_requirements.txt` chýba pripnutý tag alebo commit, alebo riadok nemá `@…` (potom sa berie `main`). |

# 28. Zmeny

Verzia v kóde je **3.1.0** (vydanie na GitHube; predchádzajúce vydania 3.0.0, 2.5.0 a 2.0.0). Pôvodný základ bol 0.38.4 (commit 7bed7de); priebežné čísla 2.0.1 až 2.2.2 v histórii commitov boli pracovné označenia a patria do línie 2.0.0 a 2.5.0.

## 28.1 3.1.0: podmienky polí a pracovný čas

- **Podmienky pravidla poľa:** rozbaľovací zoznam **výberového vlastného poľa** (select aj multiselect) a poľa s **pevným zoznamom** (napríklad stav zariadenia) ponúka len hodnoty, ktoré pravidlo povoľuje (predtým ponúkol všetky a ostatné odmietol až pri uložení). Hodnota mimo podmienky sa odmietne aj pri zápise cez REST API pri poliach modelu. Ak sa tá istá sada hodnôt používa vo viacerých poliach, zoznam ukáže hodnoty, ktoré povoľuje ktorékoľvek z nich.
- **Pracovný čas osoby len s PIN-om:** zmenené dni alebo hodiny pri voľbe *všeobecné pravidlá* sa už nestratia potichu, ale plugin to povie a vyzve na *vlastné pravidlá* alebo *bez obmedzenia*. Pri každej osobe je napísané, aký čas má (individuálne / vypnutý / platí všeobecný). Návrat na všeobecné pravidlá vezme čas zo všeobecných pravidiel.
- **E-mail a Audit log zmien:** predmet *OC : vytvorený Tenant – názov* (*zmena parametrov*, *zmazaný*), telo *USER PIN : OC* a riadok ** Pole: hodnota* pre každé vyplnené pole (pri zmene z → na), súvisiace objekty menom, prázdne polia sa vynechajú, tajné hodnoty skryté. Audit log má ten istý prvý riadok a riadky polí pod šípkou. Plánovanie e-mailov (súhrn / pri každej zmene) sa nezmenilo.
- **Editor podmienok:** *Pridať* pri „je jedno z“ pridá všetky označené hodnoty (predtým každú druhú).
- Bez nových migrácií (migrácie do `0046`).

## 28.2 3.0.0: bezpečnostné opravy po audite

- **Falošná hlavička `Authorization`** pri prihlásenej relácii už nevypne PIN ochranu (REST ani GraphQL; čítanie ani zápis). Požiadavka je tokenová, len keď ju NetBox skutočne overil tokenom.

- **`API tokeny` a `API`** sú pri výnimke dve samostatné oprávnenia (token aj relácia, REST aj GraphQL). `API` vypnuté blokuje všeobecné REST a GraphQL aj v prehliadači (okrem výberu hodnôt v rozbaľovacích zoznamoch formulárov). Správa tokenov sa riadi len oprávnením `API tokeny`.
- **Vlastné API kľúče:** pri zapnutej ochrane každý (aj superuser a držiteľ výnimky) vidí a mení len svoje kľúče; cudzie spravuje len strážca.
- **Default deny pre účet:** cesta osobného účtu a aplikácie používateľov, ktorú nikto nezaradil, je zakázaná. Pridané sú dvojčatá povolení (`/api/users/config`, záložky, odbery a notifikácie v `extras`).
- **Fail closed:** keď plugin nevie prečítať stav ochrany z databázy, nič nepovolí (HTTP 503); posledný známy stav drží najviac 30 s. Prázdny zoznam oblastí je len výsledok úspešného čítania.
- **Zdieľaná cache:** zmena výnimky, strážcu alebo oblasti sa prejaví v ostatných procesoch NetBoxu do ~0,5 s; koniec výnimky je presný aj bez `netbox-rq`.
- **API tokeny ostávajú mimo PIN ochrany** (vedomé rozhodnutie, variant A): pozri kapitolu Ochrana a výnimky.
- Bez nových migrácií (migrácie do `0046`) a bez zmeny databázy: návrat na 2.5.0 je jedným príkazom.

## 28.3 2.5.0: zmeny oproti 2.0.0 (výnimky, e-maily a audit, osobné číslo)

- Výnimka už nie je „všetko alebo nič“: strážca zaškrtáva, čo smie používateľ používať (heslo predvolene povolené; profil, predvoľby, záložky, notifikácie, odbery, API tokeny a API s tokenom na povolenie).
- Čo nie je povolené, je skryté z menu a kariet a zakázané priamou adresou (403); token bez povoleného API je odmietnutý. Strážca je bez obmedzení.
- Odkaz „Zmeniť heslo“ v menu používateľa; zvonček sa skryje, ak nie sú povolené notifikácie.
- Šípka ▾ pod menom používateľa so zaškrtávacími poľami a zelenými/červenými štítkami; existujúci používateľ sa neponúka znova a opätovné pridanie nič neprepíše.
- Nové pole `PolicyException.allowed` (migrácia `0042`); slovenský preklad.
- **Prepínač výnimky** (*Výnimka zapnutá / vypnutá*) pri každom používateľovi: vypnutá výnimka nechá používateľa riadiť PIN-om bez odobratia riadku; zapnutá ho nechá riadiť NetBoxom.
- **Úprava konca výnimky** (dátum a čas, prázdne = bez konca); po uplynutí sa prepínač sám prepne na *vypnutá* (systémová úloha, audit, e-mail strážcom); ukončenú výnimku treba pred zapnutím predĺžiť.
- **Hľadanie a stránkovanie** zoznamu výnimiek (meno, účet, dôvod; filter stavu; po 25) a vyhľadávacie pole pri pridávaní používateľa.
- Nové pole `PolicyException.active` (migrácia `0043`).
- **Pomocné polia formulárov** (Owner group, Tenant group, Contact group, výbery lokality pri kábloch, rack a pod.) sa skrývajú a zamykajú spolu s poľom, ku ktorému patria; plugin ich nájde sám zo väzieb výberov (overené na všetkých 221 formulároch NetBoxu 4.7.2).
- **E-maily a audit zmien v chránených oblastiach**: zmena objektu používateľom v skupine sa zapíše do Audit logu a strážcovia a správca úseku dostanú e-mail (súhrn alebo pri každej zmene). Nové polia v nastaveniach (migrácia `0044`).
- **Osobné číslo + PIN** pre osoby len s PIN-om: osobné číslo je povinné, jedinečné a nemenné; osoba sa volá `UserPIN : OC` všade; prihlásenie číslom a PIN-om, PIN nemusí byť jedinečný; globálne pravidlá (povinné číslo, najkratší PIN, písmeno, číslica) s e-mailom a vynútenou zmenou PINu; červený oznam na prihlasovacej stránke. Migrácia `0046`.
- **Audit zmien objektov** aj pre osoby len s PIN-om, s rozbaliteľným detailom zmenených polí (hodnoty tajných polí skryté).
- Osoba len s PIN-om vidí **len oblasti svojich skupín** (vždy režim B).

## 28.4 Kľúče a bezpečnosť

- Rotácia kľúča pokrýva aj 2FA, záložné kódy, SMTP heslo a index osôb len s PIN-om; `userpin_check` overí všetky šifrované hodnoty.
- Odstránenie PINu používateľa bez 2FA; `userpin_area_owners` kontroluje oprávnenosť.
- Master spravuje PINy, kým nie je zástupca CORE, aj pri existujúcich strážcoch.

## 28.5 Nový model ochrany

- PIN riadi iba osoby len s PIN-om a používateľov v skupine alebo správcov úsekov; ostatní pracujú podľa oprávnení NetBoxu (menu a API kľúče vrátane).
- Osoby len s PIN-om nie sú používatelia NetBoxu (skryté v zoznamoch), nemajú žiadosti a bez skupiny môžu len zmeniť PIN.
- Ochrana ZAP riadi všetkých okrem strážcov a výnimiek; VYP necháva NetBox a pozastaví osoby len s PIN-om. Prepínač ZAP/VYP je v rozhraní (len strážcovia) a ukazuje skutočný stav. Výnimka vs. skupina: skupina čaká pod výnimkou.
- Strážcovia ochrany: pravidlo posledného strážcu, núdzové príkazy (`userpin_keeper`, `userpin_default_deny`).

## 28.6 Správcovia úsekov a žiadosti

- Správca úseku s plnou mocou nad svojím úsekom (strážcovia nad ním); osoby len s PIN-om pod správcom; žiadosti správcovi aj strážcom s e-mailami o rozhodnutiach.
- Vymenúva len strážca; uvoľnená oprávnenosť (PIN + 2FA, bez roly oddelenia).

## 28.7 Osoby len s PIN-om

- E-maily oboma smermi: osoba o zmenách správcu; správcovia zhrnutie každých N minút alebo pri každej zmene (nie oboje), predmet *OC : vytvorený Tenant – názov* (alebo *zmena parametrov*, *zmazaný*), telo: *USER PIN : OC* a riadok na každé vyplnené alebo zmenené pole (súvisiace objekty menom); odosielanie po uložení cez `netbox-rq`.
- Rozbaľovacie zoznamy vo formulároch fungujú; ukladanie vlastných stĺpcov tabuliek.
- Podmienky pre polia typu relácia: obsahuje / začína na / je jedno z, viac hodnôt, tlačidlo Podmienky.

## 28.8 Pracovný čas

- Všeobecné a vlastné pravidlá, krajina so štátnymi sviatkami (knižnica `holidays`), pracovné dni a hodiny; vždy zobrazený pracovný čas.
- Mimo času len čítanie; po konci 30 minút a jedno uloženie; krajina v jazyku osoby, dni Po–Pi.

## 28.9 Nástroje

- `tools/pin_check.sh`: kontrola zvonku aj na serveri; závislosť `holidays` v `pyproject.toml`; slovenské preklady; príprava `local_requirements.txt` pre upgrade NetBoxu v rámci 4.7.x.

## 28.10 Čo plugin zatiaľ nerobí

- Dovolenky a vlastné firemné voľné dni v pracovnom čase.
- API pre bežných používateľov v skupine je stále riadené právami skupiny (nie je úplne uzavreté).
- Samostatný port alebo hostname pre prihlásenie osôb len s PIN-om (rieši sa v nginxe a firewalle).